ESEN

C I B E R S E G U R I D A D

Guía Maestra del Proyecto Final

Guía del Estudiante: línea base de seguridad de una organización, paso a paso por entregables E.01–E.12

CIS Controls v8.1 (2024) · ISO/IEC 27001 y 27002:2022 · NIST SP 800-30 r1 · NIST CSF 2.0 (2024) · ISO 22301:2019 · Enfoque PDCA

Docente: Ing. Héctor Cuchilla · Edición 2026 · con Anexos J y K

ESEN – CIBERSEGURIDAD – CICLO 03 – 2026

Tabla de contenidos

1. El proyecto: qué se construye y por qué 3
2. El producto final y su evaluación 4
3. Roles del equipo 4
4. Alcance en tres niveles de profundidad 5
5. Mapa del proyecto 5
6. Cronograma de entregas — ciclo 03-2026 6
7. Checklist maestro del proyecto 7
8. Método de trabajo y calidad 8
9. Ruta paso a paso por entregable 9
    E.01 — Equipo y organización 9
    E.02 — Compromiso de la dirección y alcance del SGSI 11
    E.03 — BIA: procesos críticos y consolidación 14
    E.04 — Inventario y clasificación de activos críticos 18
    E.05 — Matriz de riesgos 20
    E.06 — Matriz RACI 22
    E.07 — Seis controles a profundidad (política + SOP + controles) 24
    E.08 — Baseline según el Grupo de Implementación asignado 26
    E.09 — Indicadores de cumplimiento y auditoría interna 29
    E.10 — Roadmap de madurez hacia el IG asignado 30
    E.11 — Documento final integrado 32
    E.12 — Presentación ejecutiva y defensa oral 35
Anexo J — Rúbricas de evaluación (45 % = 20 + 15 + 10) 37
    J.1 Entregables parciales — 20 % 37
    J.2 Informe final — 15 % 37
    J.3 Defensa oral — 10 % 38
Anexo K — Referencia al Catálogo de Empresas 2026 38
Referencias 39

1. El proyecto: qué se construye y por qué

Este documento es la **Guía Maestra del Proyecto Final** que citan las guías de las Semanas 1 y 2, el Catálogo de Empresas 2026 y la Guía del Estudiante del BIA, en su edición como guía del estudiante: el instrumento único que cada equipo sigue de principio a fin, con la ruta de doce entregables E.01–E.12, sus plantillas, ejemplos, checklists y rúbricas.

El Proyecto Final consiste en diseñar la **línea base de seguridad** de una organización del Catálogo de Empresas 2026 (Anexo K): el conjunto fundamental de políticas, procedimientos y controles que protegen sus procesos críticos. El trabajo es de análisis y documentación, el mismo que ejecuta una firma consultora de ciberseguridad cuando un cliente le encarga levantar su programa de seguridad desde el análisis de impacto y de riesgo hasta el plan de implementación. Cada equipo asume ese rol durante el ciclo completo, con asesoría de treinta minutos cada semana, y sustenta el resultado ante el docente en una defensa oral de diez minutos.

El proyecto combina los marcos que la industria combina. **ISO/IEC 27001:2022** aporta el sistema de gestión (contexto, liderazgo, riesgo, mejora continua) y su catálogo **ISO/IEC 27002:2022** los 93 controles de referencia; los **CIS Controls v8.1** (Center for Internet Security, 2024) aportan el cómo técnico: 18 controles con 153 salvaguardas priorizadas en tres Grupos de Implementación. El análisis de impacto sigue **ISO 22301:2019** e **ISO/TS 22317:2021** (Guía del Estudiante del BIA, Semana 2); el análisis de riesgo sigue **NIST SP 800-30 r1**; el programa se organiza con las seis funciones de **NIST CSF 2.0** (2024): gobernar, identificar, proteger, detectar, responder y recuperar; y el ciclo **PDCA** (Planear–Hacer–Verificar–Actuar) ordena las fases. Toda organización del catálogo trata datos personales, de modo que la **Ley para la Protección de Datos Personales de El Salvador (D.L. 144/2024)** entra como requisito legal, incluida la notificación de toda vulneración de seguridad de datos personales a la Agencia de Ciberseguridad del Estado, a la Fiscalía General de la República y a los titulares afectados en un máximo de 72 horas (art. 25).

Cada entregable cumple una función precisa dentro de ese sistema y alimenta al siguiente; la cadena BIA → activos → riesgos → controles es la columna vertebral del proyecto:

Entregable	Función dentro del programa de seguridad
E.01 Equipo y organización	Fija el equipo consultor, los roles y la organización con su IG asignado.
E.02 Compromiso y alcance del SGSI	La dirección respalda el programa y delimita el terreno protegido (ISO/IEC 27001:2022, cláusulas 4 y 5).
E.03 BIA	Determina qué procesos son críticos, cuánto tolera la organización su interrupción y cuánto cuesta cada hora (ISO 22301:2019).
E.04 Activos críticos	Los recursos que sostienen esos procesos, con dueño y clasificación (CIS v8.1, controles 1–3).
E.05 Matriz de riesgos	Prioriza qué amenazas sobre qué activos importan más (probabilidad × impacto, NIST SP 800-30 r1).
E.06 Matriz RACI	Asigna dueños a las actividades de seguridad; sin responsables definidos el programa carece de sostenibilidad.
E.07 Seis controles a profundidad	Las medidas concretas que reducen los riesgos prioritarios: política + SOP + controles.
E.08 Baseline según el IG asignado	Las 153 salvaguardas de CIS v8.1 (IG3), fuera de los seis controles de E.07.
E.09 Indicadores y auditoría interna	Verifican que los controles operan: la V del ciclo PDCA (ISO/IEC 27001:2022, cláusula 9).
E.10 Roadmap de madurez	Ordena en el tiempo lo que queda por implantar hasta alcanzar el IG asignado.
E.11 Documento final integrado	El informe de la línea base con las trece secciones.

Entregable	Función dentro del programa de seguridad
E.12 Presentación ejecutiva y defensa	La síntesis ante la dirección simulada y el docente.

2. El producto final y su evaluación

- Un **documento profesional** (E.11) con la línea base de seguridad de la organización, con la estructura de trece secciones de la sección E.11.
- Una **defensa oral** de diez minutos ante el docente (E.12), con el guion de nueve bloques de la sección E.12.
- Se desarrolla **en equipo**, en paralelo a las clases, con **asesoría de 30 minutos cada semana** y entregas parciales en las fechas del cronograma (sección 6).

El Proyecto Final vale el **45 %** de la nota del ciclo (25 % participación y laboratorios · 15 % primer parcial · 15 % segundo parcial · 45 % Proyecto Final), distribuido en tres componentes cuyas rúbricas detalladas están en el **Anexo J**:

Componente	Peso	Qué comprende
Entregables parciales (J.1)	20 %	E.01 a E.09, evaluados a la entrega en sus cuatro hitos (S1–S2 · S2–S4 · S4–S5 · S6–S7).
Informe final (J.2)	15 %	E.10 y E.11: el documento consolidado de la S8 con las trece secciones.
Defensa oral (J.3)	10 %	E.12: la presentación ejecutiva de 10 minutos y las respuestas del equipo.

3. Roles del equipo

El equipo opera como una firma consultora: cada integrante asume un rol con responsabilidades definidas, y todos dominan el contenido completo, porque la defensa evalúa a cada integrante sobre cualquier parte del proyecto. El equipo tiene seis integrantes y cubre los cinco roles: dos integrantes comparten el rol de analista de riesgos o el de arquitecto de controles, que son los que concentran la carga del proyecto, y el acta declara quién responde por el rol.

Rol	Responsabilidades principales
Consultor líder	Coordina el plan de trabajo, administra el cronograma de entregas, dirige la relación con el docente en las asesorías y consolida las decisiones del equipo.
Analista de riesgos	Conduce el BIA (E.03), el inventario de activos (E.04) y la matriz de riesgos (E.05); custodia la coherencia entre el análisis y la selección de controles.
Arquitecto de controles	Dirige el desarrollo de los seis controles (E.07), el checklist del baseline (E.08) y los indicadores (E.09); asegura el sustento en CIS v8.1 e ISO/IEC 27002:2022.
Oficial de documentación	Integra el documento final (E.11) con la identidad y estructura requeridas; administra versiones y evidencias.
Oficial de calidad	Corre el checklist de cierre de cada entregable contra su criterio de rúbrica antes de entregar; audita la trazabilidad riesgo → control → indicador.

4. Alcance en tres niveles de profundidad

Los CIS Controls v8.1 (2024) organizan sus 153 salvaguardas en tres **Grupos de Implementación (IG)** acumulativos: **IG1**, la higiene cibernética esencial con 56 salvaguardas que toda organización implementa primero; **IG2**, que agrega 74 salvaguardas para organizaciones con datos sensibles u operación compleja (130 en total); e **IG3**, que agrega 23 más hasta las 153, para blancos de alto valor e infraestructura crítica. Cada organización del catálogo trae su **IG asignado** según su perfil de riesgo inherente, y las veintisiete quedan en **IG3**: el baseline del proyecto son las 153 salvaguardas (Anexo K), y el proyecto ejercita la destreza central del oficio: priorizar. El alcance tiene tres niveles:

1. **A profundidad — seis controles seleccionados (E.07).** El equipo elige seis controles de CIS v8.1 que mitiguen los riesgos Críticos y Altos de su matriz, y para cada uno desarrolla política, SOP y controles técnicos, administrativos y físicos. La selección se justifica con la matriz de riesgos: cada control elegido nombra los riesgos que reduce.
2. **Baseline según el IG asignado — el resto (E.08).** Para los demás controles, el equipo mapea todas las salvaguardas del IG asignado, que es IG3 en las veintisiete organizaciones (las 56 de IG1, las 74 de IG2 y las 23 de IG3, 153 en total): qué medida las cubre en la organización, con una línea de justificación por salvaguarda y sin desarrollo a fondo.
3. **Roadmap — en el tiempo (E.10).** Las salvaguardas pendientes y las mejoras que la auditoría anticipa van al roadmap de madurez, organizadas en corto, mediano y largo plazo hasta alcanzar el IG asignado.

El resultado es un proyecto realizable con calidad, que demuestra dominio de la priorización: profundizar donde el riesgo lo exige, cubrir el baseline completo del IG asignado y planear su implantación.

5. Mapa del proyecto

La tabla resume la ruta completa: cada entregable, la fase PDCA y la semana en que se construye, la plantilla que lo formaliza, el hito de entrega y el criterio de la rúbrica que lo evalúa. Los entregables se construyen en este orden porque cada uno toma como insumo la salida del anterior (sección 9). El ensamblaje parcial de las secciones 1–7 del documento final (E.11) puede iniciarse en la S6, con los entregables de H1 a H3 ya retroalimentados.

Entregable	Fase	Semana	Plantilla	Hito	Criterio (peso)
E.01 Equipo y organización	Fase 0	S1	E01_Acta_Equipo_Seleccion_Empresa	H1 · S1–S2	J.1.1 (1 %)
E.02 Compromiso de la dirección y alcance del SGSI	Fase 0	S1–S2	E02_Compromiso_Direccion_Alcance_SGSI	H1 · S1–S2	J.1.2 (2 %)
E.03 BIA: procesos críticos y consolidación	PLAN	S2–S4	E03_BIA_Consolidacion_Procesos_Criticos + BIA_P01–P07	H2 · S2–S4	J.1.3 (3 %)
E.04 Inventario y clasificación de activos críticos	PLAN	S3–S4	E04_Inventario_Clasificacion_Activos	H2 · S2–S4	J.1.4 (2 %)
E.05 Matriz de riesgos	PLAN	S4–S5	E05_Matriz_Riesgos	H3 · S4–S5	J.1.5 (4 %)
E.06 Matriz RACI	PLAN	S5	E06_Matriz_RACI	H3 · S4–S5	J.1.6 (1 %)
E.07 Seis controles a profundidad (política + SOP + controles)	DO	S6	E07_Desarrollo_Control_CIS	H4 · S6–S7	J.1.7 (3 %)
E.08 Baseline según el Grupo de Implementación asignado	DO	S6–S7	E08_Checklist_Baseline_IG	H4 · S6–S7	J.1.8 (3 %)
E.09 Indicadores de cumplimiento y auditoría interna	CHECK	S7	E09_Indicadores_Auditoria_Interna	H4 · S6–S7	J.1.9 (1 %)

Entregable	Fase	Semana	Plantilla	Hito	Criterio (peso)
E.10 Roadmap de madurez hacia el IG asignado	ACT	S8	E10_Roadmap_Madurez_IG	H5 · S8	J.2.4 (2 %)
E.11 Documento final integrado	ACT	S8	E11_Documento_Final_LineaBase	H5 · S8	J.2 (15 %, cinco criterios)
E.12 Presentación ejecutiva y defensa oral	Defensa	12–14 de noviembre	E12_Presentacion_Ejecutiva	H6 · Semana de defensa (S8)	J.3 (10 %, cuatro criterios)

6. Cronograma de entregas — ciclo 03-2026

Hito	Semana	Fecha de entrega	Entregables	Fase	Peso
H1	S1–S2	viernes 25 de septiembre (E.01) y viernes 2 de octubre (E.02)	E.01, E.02	Fase 0	3 %
H2	S2–S4	viernes 16 de octubre	E.03, E.04	PLAN	5 %
H3	S4–S5	viernes 23 de octubre	E.05, E.06	PLAN	5 %
H4	S6–S7	viernes 30 de octubre (E.07) y viernes 6 de noviembre (E.08, E.09)	E.07, E.08, E.09	DO / CHECK	7 %
H5	S8	miércoles 11 de noviembre	E.10, E.11	ACT	15 % (J.2)
H6	Semana de defensa (S8)	12 al 14 de noviembre	E.12	Defensa	10 % (J.3)

Las fechas se refieren al calendario del ciclo publicado en Moodle (S1 = semana del 21 de septiembre; S8 = semana del 9 de noviembre; la entrega máxima del ciclo es el sábado 14 de noviembre) y se ajustan a ese calendario si la coordinación académica lo modifica. Cada semana incluye la asesoría de 30 minutos, que rinde con avances y preguntas concretas sobre el entregable en curso. La retroalimentación de cada hito se incorpora al entregable antes de integrarlo en E.11. El docente publica el registro de asignaciones el lunes 28 de septiembre. Algunos entregables tienen una versión 1.1 que se entrega en un hito posterior: el acta E.01, con la organización asignada, junto con E.02 (2 de octubre); E.02, con la revisión del alcance tras el BIA (sección A.3), junto con E.03 (16 de octubre); y E.03, E.04 y BIA_P07, con los ID de riesgo y las secciones 8 a 11 del informe, junto con E.05 (23 de octubre).

Esfuerzo estimado por hito. Horas de equipo, sumadas entre los integrantes, medidas en la simulación de cátedra del 17 de septiembre de 2026 con las plantillas completas y ajustadas al diseño vigente. Incluyen la lectura del perfil y de la ficha, los cálculos y la redacción, y sirven para repartir el trabajo y detectar a tiempo una semana cargada.

Hito	Entregables	Horas de equipo	Detalle medido
H1	E.01, E.02	8	E.01, 2 · E.02, 6
H2	E.03 con BIA_P01–P07, E.04	44	E.03, 38 (BIA_P02 toma 10 y BIA_P03, 6) · E.04, 6
H3	E.05, E.06	25	E.05, 20 · E.06, 5
H4	E.07, E.08, E.09	68	E.07, 42 (unas 7 por control) · E.09, 8 · E.08, el resto, con la tabla G.2 precargada
S6	Ensamblaje parcial de E.11 (secciones 1–7)	9	Se adelanta a la S6 para descargar la S8
H5	E.10, E.11	15	E.10, 10 · cierre del ensamblaje de E.11

Hito	Entregables	Horas de equipo	Detalle medido
H6	E.12	10	Guion, reparto, ensayos y preparación de respuestas
Total	Proyecto completo	179	Unas 30 horas por integrante en un equipo de seis: 3,7 horas por semana, con un pico cercano a 5,7 en S6–S7

7. Checklist maestro del proyecto

Casillas en orden cronológico, agrupadas por fase. El oficial de calidad las marca conforme el equipo cierra cada entregable con su checklist de cierre (sección 9); la última fase corresponde al ensamblaje y a la defensa.

Fase 0 — Compromiso y alcance (S1–S2)

☐ E.01 Equipo y organización — construido con su checklist de cierre en verde, entregado en Moodle como E01_Acta_Equipo_Seleccion_Empresa_<Equipo> (viernes 25 de septiembre).

☐ E.02 Compromiso de la dirección y alcance del SGSI — construido con su checklist de cierre en verde, entregado en Moodle como E02_Compromiso_Direccion_Alcance_SGSI_<Equipo> (viernes 2 de octubre).

PLAN — Planear (S2–S5)

☐ E.03 BIA: procesos críticos y consolidación — construido con su checklist de cierre en verde, entregado en Moodle como E03_BIA_Consolidacion_Procesos_Criticos_<Equipo> (viernes 16 de octubre).

☐ E.04 Inventario y clasificación de activos críticos — construido con su checklist de cierre en verde, entregado en Moodle como E04_Inventario_Clasificacion_Activos_<Equipo> (viernes 16 de octubre).

☐ E.05 Matriz de riesgos — construido con su checklist de cierre en verde, entregado en Moodle como E05_Matriz_Riesgos_<Equipo> (viernes 23 de octubre).

☐ E.06 Matriz RACI — construido con su checklist de cierre en verde, entregado en Moodle como E06_Matriz_RACI_<Equipo> (viernes 23 de octubre).

DO — Hacer (S6–S7)

☐ E.07 Seis controles a profundidad (política + SOP + controles) — construido con su checklist de cierre en verde, entregado en Moodle como E07_Desarrollo_Control_CIS_<Control>_<Equipo> (viernes 30 de octubre).

☐ E.08 Baseline según el Grupo de Implementación asignado — construido con su checklist de cierre en verde, entregado en Moodle como E08_Checklist_Baseline_IG_<Equipo> (viernes 6 de noviembre).

CHECK — Verificar (S7)

☐ E.09 Indicadores de cumplimiento y auditoría interna — construido con su checklist de cierre en verde, entregado en Moodle como E09_Indicadores_Auditoria_Interna_<Equipo> (viernes 6 de noviembre).

ACT — Actuar (S8)

☐ E.10 Roadmap de madurez hacia el IG asignado — construido con su checklist de cierre en verde, entregado en Moodle como E10_Roadmap_Madurez_IG_<Equipo> (miércoles 11 de noviembre).

☐ Ensamblaje parcial de las secciones 1–7 del documento final (E.11) iniciado en la S6, con los entregables de H1 a H3 ya retroalimentados.

Ensamblaje del documento final (S8)

☐ E.11 Documento final integrado — construido con su checklist de cierre en verde, entregado en Moodle como E11_Documento_Final_LineaBase_<Organizacion>_<Equipo> (miércoles 11 de noviembre).

☐ Retroalimentación de H1–H4 incorporada en cada sección antes del ensamblaje.

☐ Trazabilidad verificada de extremo a extremo: riesgo → control → indicador, y BIA → activos → riesgos.

☐ PDF final sobre la plantilla E11, con portada, registro formal, índice, numeración, bibliografía con ediciones y años, Anexo A de supuestos, Anexo B de retroalimentación aplicada y los anexos del BIA adjuntos.

Defensa (12–14 de noviembre)

☐ E.12 Presentación ejecutiva y defensa oral — construido con su checklist de cierre en verde, entregado en Moodle como E12_Presentacion_Ejecutiva_<Organizacion>_<Equipo> (fecha y hora asignadas por el docente).

☐ Presentación de nueve bloques ensayada con cronómetro en diez minutos.

☐ Cada integrante preparado para responder sobre cualquier sección del documento.

8. Método de trabajo y calidad

- **Adaptación real:** toda política, procedimiento y control se redacta para la organización asignada: su sector, sus procesos, sus riesgos del catálogo. El material genérico sin adaptar se califica como ausente.
- **Perfil fijo, ficha de datos y supuestos declarados:** el perfil del catálogo y la ficha de datos del cliente se toman tal como están escritos, y un dato que la ficha trae nunca se sustituye por un supuesto. Solo lo que ni el perfil ni la ficha traen se declara como supuesto, con su fundamento y coherente con ambos, en la sección «Supuestos declarados en este entregable» de la plantilla. Los supuestos se numeran de forma global y correlativa en todo el proyecto (S-01, S-02…): cada entregable continúa la numeración del anterior y E.11 los consolida en su Anexo A.
- **Trazabilidad:** cada control desarrollado nombra los riesgos de la matriz que mitiga, y cada riesgo Crítico o Alto tiene tratamiento definido. El oficial de calidad audita esa cadena antes de cada entrega.
- **Diferencia política / SOP:** la política declara la regla (el qué y el porqué); el SOP prescribe los pasos (el cómo, quién y con qué frecuencia). Cada control de E.07 contiene ambos, diferenciados.
- **Uso de IA como apoyo:** permitido para redactar y explorar; el equipo comprende y defiende cada decisión, y la defensa oral lo comprueba con preguntas individuales.
- **Ritmo:** cada hito se entrega en su fecha y la asesoría semanal se usa con avances concretos; el BIA y la matriz de riesgos son la columna vertebral, y con ellos bien construidos el resto del proyecto fluye.
- **Ejemplo de referencia:** cada sección de la ruta incluye un ejemplo resuelto con la Red Hospitalaria Metropolitana (RHM, n.º 2 del catálogo, IG3), la misma organización del caso de la Guía del Estudiante del BIA; sus cifras salen de la ficha de RHM (perfil n.º 2) y cada equipo trabaja con la ficha de su organización. El paquete incluye además el proyecto completo resuelto con ENSA (perfil n.º 4, carpeta 06_Proyecto_Ejemplo_ENSA): RHM ilustra cada paso dentro de su ficha y ENSA muestra el formato y la extensión de un proyecto terminado; la regla la fija siempre esta guía.

9. Ruta paso a paso por entregable

Cada sección sigue la misma estructura: objetivo, insumos (qué salida previa usa), pasos numerados, plantilla y llenado campo por campo, ejemplo resuelto con RHM, errores frecuentes, checklist de cierre (cada comprobación cita el criterio de la rúbrica que la evalúa), entrega y qué alimenta. La plantilla de cada entregable es su archivo de la carpeta 03_Plantillas_Entregables del paquete (E01 a E11 en DOCX y E12 en PPTX); esta guía describe su llenado y remite al archivo, que es el formato oficial. La portada, la tabla de contenidos y las instrucciones de la plantilla se conservan y no cuentan para la extensión de referencia, que se mide sobre el desarrollo. Cada plantilla E01–E10 cierra con la sección «Supuestos declarados en este entregable» (sección 8).

E.01 — Equipo y organización

Fase	Semana de construcción	Entrega	Evalúa
Fase 0	S1	viernes 25 de septiembre	J.1.1 — E.01 Acta de equipo y organización (1 %)

Objetivo

Constituir el equipo consultor, asignar los cinco roles y fijar la organización del Catálogo 2026 sobre la que se construye todo el proyecto, con su Grupo de Implementación asignado.

Insumos

- Catálogo de Empresas 2026: perfiles de la sección 4, asignación de IG de la sección 3 y reglas de selección de la sección 5.
- Sección 3 de esta guía (roles del equipo).

Pasos

1. Conformar el equipo de seis integrantes y repartir los cinco roles de la sección 3; dos integrantes comparten el rol de analista de riesgos o el de arquitecto de controles, con un responsable declarado en el acta.
2. Leer los veintisiete perfiles del catálogo con su ficha de datos del cliente y ordenar tres organizaciones por preferencia, con el IG que el catálogo les asigna, aplicando tres o cuatro criterios declarados: afinidad del equipo con el sector; lo que la ficha anticipa del trabajo (procesos, sistemas, datos personales y pagos con tarjeta); la madurez actual que describe el perfil; y el interés profesional de los integrantes. Un párrafo de justificación explica el orden con esos criterios.
3. Registrar la elección en el aula virtual: la primera solicitud válida asigna la organización y la bloquea para los demás equipos.
4. Entregar el viernes 25 de septiembre el acta con integrantes, roles, las tres preferencias y el plan de trabajo (versión 1.0). El docente publica el registro de asignaciones en Moodle el lunes 28 de septiembre; el equipo actualiza el acta a la versión 1.1 con la organización asignada, su IG y la fecha de asignación, tomados de ese registro, y la entrega junto con E.02 el viernes 2 de octubre; los dos integrantes que comparten el rol de analista de riesgos o el de arquitecto de controles anotan el rol compartido y el responsable declarado en su fila.
5. Acordar el plan de trabajo del ciclo en la tabla «Plan de trabajo acordado» (reunión semanal, responsable de cada entregable E.01–E.12 y revisión del oficial de calidad antes de cada entrega) y firmar los cuatro compromisos del acta: perfil y ficha fijos, baseline hacia el IG asignado, dominio completo por cada integrante y conocimiento del calendario E.01–E.12.

Plantilla E01_Acta_Equipo_Seleccion_Empresa.docx — llenado campo por campo

Formato oficial: 03_Plantillas_Entregables/E01_Acta_Equipo_Seleccion_Empresa.docx. Las filas «(p. ej.)» de la plantilla se reemplazan por los datos de la organización.

Campo	Cómo se completa
Integrantes y roles	Nombre, carné, correo institucional y uno de los cinco roles de la sección 3; cada rol aparece al menos una vez.
Selección de la organización	Tres filas con número de catálogo, nombre y IG, en orden de preferencia; debajo, los tres o cuatro criterios usados y el párrafo que justifica el orden.
Organización asignada	La que el docente publica el lunes 28 de septiembre en el registro de asignaciones; número, IG, fecha y, solo si aplica, la autorización para compartir organización; se registra en la versión 1.1 del acta.
Plan de trabajo acordado	Reunión semanal del equipo, responsable de cada entregable E.01–E.12 y revisión del oficial de calidad antes de cada entrega.
Compromisos del equipo	Las cuatro casillas marcadas; sin casilla marcada el acta está incompleta.
Firmas	Firma y fecha de cada integrante.
Supuestos declarados en este entregable	Solo lo que ni el perfil ni la ficha de datos del cliente traen, con identificador global S-nn, supuesto y fundamento; un dato de la ficha nunca se sustituye por un supuesto. E.11 los consolida en su Anexo A.

Ejemplo resuelto — Red Hospitalaria Metropolitana (RHM, IG3)

El equipo «Consultores RHM» registra como primera opción la n.° 2, Red Hospitalaria Metropolitana (RHM), IG3; como segunda, la aseguradora n.° 8 (IG3); como tercera, la fintech n.° 25 (IG3). Ordena con tres criterios —interés de los integrantes en el sector salud, lo que la ficha de RHM anticipa (cuatro procesos que el perfil declara críticos, 310 000 pacientes con expediente clínico y entre 350 y 500 dispositivos médicos conectados sin inventario) y la madurez actual del perfil— y lo justifica en un párrafo. El docente asigna RHM. El acta registra IG3 como Grupo de Implementación asignado: desde este momento el baseline del equipo son las 153 salvaguardas de CIS Controls v8.1 y el roadmap ordena su implantación en el tiempo.

Integrante	Rol
Integrante 1	Consultor líder
Integrante 2	Analista de riesgos
Integrante 3	Analista de riesgos (comparte; responsable: Integrante 2)
Integrante 4	Arquitecto de controles
Integrante 5	Oficial de documentación
Integrante 6	Oficial de calidad

Errores frecuentes

- Elegir la organización por afinidad con el sector sin leer su madurez actual: el perfil fijo determina el trabajo de todo el ciclo.
- Registrar un IG distinto del que asigna el catálogo: el IG viene fijado por el perfil de riesgo inherente y se justifica en el proyecto, no se negocia.
- Dejar un rol sin titular; la defensa evalúa a cada integrante sobre cualquier parte del proyecto.

Checklist de cierre (correspondencia con la rúbrica)

☐ El acta tiene todos los integrantes con carné, correo y rol; los cinco roles están cubiertos. [J.1.1]

☐ Las tres preferencias están registradas con número de catálogo e IG correctos, con los criterios de orden y el párrafo de justificación. [J.1.1]

☐ La versión 1.1 del acta registra la organización asignada tal como la publica el registro del docente del lunes 28 de septiembre, con fecha y IG, y se entregó junto con E.02 el viernes 2 de octubre. [J.1.1]

☐ Las cuatro casillas de compromiso están marcadas y el acta está firmada por todos. [J.1.1]

☐ La versión 1.0 del acta, con el plan de trabajo acordado, se entregó en Moodle con el nombre normalizado el viernes 25 de septiembre (H1). [J.1.1]

Entrega

Cuándo	Formato	Nombre del archivo en Moodle
viernes 25 de septiembre	DOCX o PDF	E01_Acta_Equipo_Seleccion_Empresa_<Equipo>.docx /.pdf

Qué alimenta

E.02 toma de aquí la organización y el IG; todos los entregables posteriores llevan la misma identificación de equipo y organización.

E.02 — Compromiso de la dirección y alcance del SGSI

Fase	Semana de construcción	Entrega	Evalúa
Fase 0	S1–S2	viernes 2 de octubre	J.1.2 — E.02 Compromiso y alcance del SGSI (2 %)

Objetivo

Declarar el respaldo de la dirección al programa de seguridad y delimitar el terreno que el SGSI protege: procesos, unidades, sedes, sistemas, exclusiones y requisitos legales. Corresponde a las cláusulas 4 y 5 de ISO/IEC 27001:2022 y a la función Gobernar de NIST CSF 2.0 (2024).

Insumos

- E.01: organización y IG asignados.
- Perfil del catálogo: misión, estructura organizacional, procesos críticos declarados, infraestructura y madurez actual.
- Ficha de datos del cliente, bloque «Organización y presupuesto»: organigrama, presupuesto aprobado para seguridad, arranque del programa y cumplimiento que el cliente reconoce.

Pasos

1. Extraer del perfil el contexto del negocio: misión, procesos que sostienen los ingresos y dependencia tecnológica (tres a cinco líneas). El equipo redacta cada campo en la segunda columna de las tablas A.1 y A.2 de la plantilla, en prosa completa por fila, y sustituye la descripción que la plantilla trae en esa columna.
2. Tomar el organigrama de la fila «Organigrama» del bloque «Organización y presupuesto» de la ficha, con Legal, Auditoría y RR. HH. donde la ficha los ubica. Si no incluye una función de seguridad de la información y la fila «Presupuesto aprobado para seguridad» tampoco la crea, el equipo la crea como supuesto (unidad y cargo) y la usa como firmante aquí y como rol en E.06.

3. Redactar la declaración de compromiso en voz de la dirección simulada: la seguridad de la información como prioridad, recursos y autoridad asignados, CIS Controls v8.1 e ISO/IEC 27001:2022 adoptados como marcos.
4. Formular de tres a cinco objetivos de seguridad medibles y alineados a los procesos críticos del perfil, cada uno con fecha absoluta de cumplimiento contada desde el arranque del programa que fija la ficha, el lunes 4 de enero de 2027 (p. ej. «al 30 de junio de 2027»).
5. Fijar los compromisos concretos con el bloque «Organización y presupuesto» de la ficha: el presupuesto aprobado para seguridad de cada año, con su división en inversión y operación, y el personal que la ficha asigna o crea, copiados tal como están escritos; además, la frecuencia de la revisión por la dirección y el apoyo al ciclo PDCA.
6. Delimitar el alcance: procesos cubiertos (los que el BIA de E.03 confirmará como críticos), unidades y sedes, sistemas e infraestructura del perfil. El alcance se revisa al cerrar E.03: la versión 1.1 de E.02, que se entrega junto con E.03 el viernes 16 de octubre, completa la sección A.3 «Revisión del alcance tras el BIA» con cada diferencia entre los procesos cubiertos y la clase que BIA_P05 les asigna, una línea por diferencia.
7. Escribir las exclusiones con su justificación, una línea por exclusión.
8. Identificar partes interesadas y requisitos legales a partir de la fila «Cumplimiento que el cliente reconoce» de la ficha. Toda organización del catálogo trata datos personales: registrar la Ley para la Protección de Datos Personales (D.L. 144, D.O. 15-nov-2024) y su art. 25, que obliga a notificar toda vulneración de seguridad de datos personales a la Agencia de Ciberseguridad del Estado, a la Fiscalía General de la República y a los titulares afectados en un plazo máximo de 72 horas desde que se tiene conocimiento de ella. Las entidades públicas quedan sujetas específicamente al Título III de esa ley (art. 2, inciso segundo), y la ley excluye el tratamiento efectuado en los registros públicos y en aplicación de la ley que regula la emisión del Documento Único de Identidad (art. 3, literal d): la organización que opera un registro de ese tipo declara qué tratamientos quedan fuera por esa exclusión y cuáles siguen dentro. Registrar también la Ley de Ciberseguridad y Seguridad de la Información (D.L. 143, misma publicación) con su nota de ámbito: obliga a los órganos del Gobierno y sus dependencias, a las instituciones oficiales autónomas, a las autoridades municipales y a toda entidad que administre recursos públicos o bienes del Estado, ejecute actos de la administración pública o posea incidencia en las infraestructuras críticas de la nación (art. 2); en una organización privada que presta un servicio esencial se registra como requisito sujeto a que la Agencia la califique como operador de infraestructura crítica (art. 8, literal f). La norma sectorial que ni el perfil ni la ficha nombran se declara como supuesto.

Plantilla E02_Compromiso_Direccion_Alcance_SGSI.docx — llenado campo por campo

Formato oficial: 03_Plantillas_Entregables/E02_Compromiso_Direccion_Alcance_SGSI.docx. Las filas «(p. ej.)» de la plantilla se reemplazan por los datos de la organización.

Campo	Cómo se completa
Encabezado	Organización, fecha y firmantes simulados: dirección general y responsable de seguridad.
Contexto del negocio	Tomado del perfil y de la ficha de datos del cliente, sin inventar cifras; solo lo que ninguno de los dos trae se declara como supuesto.
Declaración de compromiso	Un párrafo en primera persona institucional; nombra los dos marcos y la autoridad del programa.
Objetivos de seguridad	Cada objetivo con verbo, meta, proceso al que sirve y fecha absoluta contada desde el arranque del 4 de enero de 2027.
Compromisos concretos	Presupuesto por año (inversión y operación) y personal del bloque «Organización y presupuesto» de la ficha, sin cambios; frecuencia de revisión explícita.
Procesos cubiertos	Los procesos críticos que el perfil declara, con el nombre exacto del catálogo.

Campo	Cómo se completa
Unidades y sedes · Sistemas	De la estructura organizacional y de la infraestructura del perfil.
Exclusiones justificadas	Qué queda fuera y por qué; una exclusión sin justificación invalida la delimitación.
Partes interesadas y requisitos	Clientes, reguladores, terceros; las normas de la fila «Cumplimiento que el cliente reconoce»; la LPDP con su art. 25 y la Ley de Ciberseguridad con su nota de ámbito.
A.3 Revisión del alcance tras el BIA	En la versión 1.1, entregada con E.03: cada diferencia entre los procesos cubiertos y la clase de BIA_P05, una línea por diferencia, con la decisión de mantener o ajustar el alcance.
Supuestos declarados en este entregable	Solo lo que ni el perfil ni la ficha de datos del cliente traen, con identificador global S-nn, supuesto y fundamento; un dato de la ficha nunca se sustituye por un supuesto. E.11 los consolida en su Anexo A.

Ejemplo resuelto — Red Hospitalaria Metropolitana (RHM, IG3)

RHM declara como objetivos, contados desde el arranque del lunes 4 de enero de 2027: mantener el expediente clínico electrónico disponible con RTO de dos horas a partir del 30 de junio de 2027; inventariar el 100 % de los dispositivos IoMT en red al 30 de junio de 2027; notificar toda vulneración de datos de salud en 72 horas conforme al art. 25 de la LPDP desde el 4 de enero de 2027. Los compromisos concretos copian la ficha: USD 420 000 aprobados para 2027 (250 000 de inversión y 170 000 de operación) y el mismo nivel para 2028 y 2029, sujeto a aprobación; el organigrama de la ficha no tiene función de seguridad y el equipo la crea como supuesto. El alcance cubre los cuatro procesos críticos del perfil (EHR, IoMT, admisión y facturación, farmacia y laboratorio), el hospital principal de San Salvador y las tres clínicas de Santa Ana y San Miguel, y los sistemas EHR/HIS, PACS, LIS y Microsoft 365. Exclusión justificada: la red de invitados, porque no sostiene ningún proceso crítico y se aísla por diseño. Partes interesadas: pacientes, compañías de seguros, Ministerio de Salud y Consejo Superior de Salud Pública, la Agencia de Ciberseguridad del Estado (autoridad de aplicación de la LPDP, art. 50) y la Fiscalía General de la República, destinataria con la Agencia y los pacientes afectados de la notificación del art. 25.

Errores frecuentes

- Copiar una declaración genérica sin nombrar los procesos del perfil: el material sin adaptar se califica como ausente.
- Objetivos sin meta medible («mejorar la seguridad»).
- Alcance que incluye toda la organización sin exclusiones: la delimitación demuestra criterio.
- Omitir la LPDP cuando el perfil trata datos personales; todas las organizaciones del catálogo los tratan.
- Sustituir el presupuesto o el personal de la ficha por cifras simuladas.
- Objetivos con plazos relativos («en seis meses») sin fecha absoluta.

Checklist de cierre (correspondencia con la rúbrica)

☐ La declaración nombra los marcos, asigna autoridad y los recursos de la ficha (presupuesto por año y personal) y fija la frecuencia de la revisión por la dirección. [J.1.2]

☐ Hay entre tres y cinco objetivos medibles, cada uno ligado a un proceso del perfil y con fecha absoluta contada desde el 4 de enero de 2027. [J.1.2]

☐ El alcance lista procesos, unidades, sedes y sistemas con los nombres del catálogo. [J.1.2]

☐ Cada exclusión tiene su justificación en una línea. [J.1.2]

☐ Los requisitos legales incluyen la LPDP con su art. 25 (72 horas; Agencia de Ciberseguridad del Estado, Fiscalía General de la República y titulares afectados) y la Ley de Ciberseguridad con su nota de ámbito. [J.1.2]

☐ La versión 1.1, entregada con E.03, trae la sección A.3 con cada diferencia entre el alcance y la clase de BIA_P05. [J.1.2]

Entrega

Cuándo	Formato	Nombre del archivo en Moodle
viernes 2 de octubre	DOCX o PDF, 2–3 páginas	E02_Compromiso_Direccion_Alcance_SGSI_<Equipo>.docx/.pdf

Qué alimenta

E.03 toma los procesos cubiertos como censo de partida del BIA; E.05 toma los requisitos legales como impacto regulatorio; E.11 los integra como secciones 2 y 3 del documento final.

E.03 — BIA: procesos críticos y consolidación

Fase	Semana de construcción	Entrega	Evalúa
PLAN	S2–S4	viernes 16 de octubre	J.1.3 — E.03 BIA (3 %)

Objetivo

Determinar qué procesos del alcance son críticos, cuánto tolera la organización su interrupción (MTPD o MTD, RTO, WRT, RPO, MBCO), cuánto cuesta cada hora y cada día de indisponibilidad, cuál es el valor del proceso, su factor de exposición y la pérdida por evento único (SLE), y cuáles son sus puntos únicos de falla. Método oficial: la Guía del Estudiante del BIA de la Semana 2, trece pasos (ISO 22301:2019, ISO/TS 22317:2021, NIST SP 800-34 Rev. 1). Los pasos 9 y 10 de esa guía (ARO, ALE, cinco pasos de justificación, ACC y ROSI) se ejecutan en E.05.

Insumos

- E.02: procesos cubiertos por el alcance.
- Perfil del catálogo: procesos críticos declarados, dependencia tecnológica, infraestructura y madurez.
- Ficha de datos del cliente: economía (ventas o ingresos anuales, titulares de datos personales y costo de notificar a un titular) y operación por proceso.
- Guía del Estudiante del BIA (secciones 4 y 5), plantillas BIA_P01–P07 y el caso resuelto de RHM.

Pasos

1. Preparar y levantar (Paso 1 de la Guía BIA): entrevista estructurada con el dueño simulado de cada proceso, cuestionario estandarizado, taller entre áreas dependientes, validación de cada ficha con el dueño y aprobación de la dirección simulada; registrar el método usado en la sección 2 de BIA_P02 de cada proceso con ficha; BIA_P07 lo resume en su sección 3.
2. Inventariar los procesos (Paso 2) en BIA_P01: nombre, área, dueño con cargo, servicio que entrega, quién lo recibe, sistemas que lo soportan y ventana de operación; los procesos críticos que el perfil declara son el mínimo, más los procesos de soporte que los alimentan. El puntaje del Paso 7 manda: un proceso que el perfil llama crítico puede resultar importante o diferible, y el equipo lo declara. Las entrevistas del Paso 1 son simuladas: las respuestas del dueño se toman del bloque «Procesos» de la ficha de datos del cliente (horario, personal, procedimiento alterno, penalizaciones y las consecuencias en los cinco cortes), y solo lo que la ficha no trae se redacta como supuesto declarado.
3. Precalificar todo el censo (regla única de fichas): calificar cada proceso de BIA_P01 en las cinco categorías en el corte de 24 horas con las consecuencias que la ficha trae para ese corte, calcular su puntaje provisional en BIA_P05 y clasificarlo. Cada proceso que resulta crítico lleva ficha BIA_P02, matriz BIA_P03 y mapa BIA_P04 completos; los importantes y diferibles llevan solo su fila en BIA_P01 y en BIA_P05, con el MTPD que declara el negocio y, cuando la ficha los trae, RTO y RPO en la lista priorizada; el proceso importante que trata los datos

personales que la ficha cuantifica lleva además las secciones 3, 8 y 9 de BIA_P02 para su SLE de exposición. Las calificaciones de BIA_P03 sustituyen después a las provisionales, y todo proceso que cambia de clase se declara en BIA_P05.

4. Fijar las métricas de tiempo (Paso 3) en la BIA_P02 de cada proceso crítico: MTPD (MTD) declarado por el negocio, RTO, WRT, RPO y MBCO; comprobar RTO + WRT ≤ MTPD y corregir la ficha si la desigualdad falla.
5. Valorar el impacto (Paso 4) en BIA_P03: definir primero la escala 1–5 de la sección 3 de BIA_P03 (criterio monetario o verbal por nivel) y el umbral de tolerancia; después calificar las cinco categorías (financiero, operativo, legal y regulatorio, reputacional, seguridad de las personas) en cinco cortes (4 h, 24 h, 72 h, 1 semana, 1 mes); fijar el umbral de tolerancia y derivar el MTPD del corte en que la curva lo cruza. Cuando el MTPD que el negocio declara cae entre dos cortes, se adopta el declarado y se registra la diferencia con el derivado; el equipo puede añadir un corte intermedio y declararlo.
6. Registrar la estacionalidad y el procedimiento alterno (Paso 5) en BIA_P02: períodos pico y evaluación en el peor escenario temporal; qué se hace, quién y con qué recursos, y la duración máxima sostenible.
7. Mapear las dependencias (Paso 6) en BIA_P04: las seis clases (personas y competencias críticas; aplicaciones y sistemas; datos y registros vitales; proveedores y terceros; instalaciones; equipamiento y servicios básicos), el recurso mínimo de recuperación al nivel del MBCO, las interdependencias entre procesos y los puntos únicos de falla, que pasan a BIA_P06.
8. Priorizar (Paso 7) en BIA_P05 con la convención del proyecto: todos los procesos se califican en el corte de 24 horas, que se anota en la línea «Corte de tiempo» de la sección 3. El corte del MTPD más corto del portafolio (4 horas en la mayoría de los perfiles) sesga el resultado: aplana los procesos que toleran unas horas y no toleran días, y los deja como diferibles aunque el perfil los declare críticos. El equipo puede declarar otra regla —cada proceso calificado en el corte de su propio MTPD— con su justificación en esa misma línea. Los pesos por categoría suman 100 % y los aprueba la dirección simulada; puntaje final = suma ponderada × (1 + 0,10 × número de procesos que dependen de él), anotado en la línea «Ajuste por dependientes» y redondeado a dos decimales, la mitad hacia arriba (4,35 con un dependiente: 4,35 × 1,10 = 4,785 → 4,79). Un proceso que el perfil declara crítico por la confidencialidad de sus datos y que puntúa bajo en disponibilidad conserva la clase de su puntaje: la criticidad por confidencialidad se registra en BIA_P06 como brecha y E.05 la trata como riesgo, con el SLE de exposición del paso siguiente. Los rangos de clase se declaran en la sección 5 de BIA_P05; lista única ordenada y clase crítico / importante / diferible.
9. Cuantificar (Paso 8): costo de la indisponibilidad por hora (ingresos no percibidos, personal improductivo o en horas extra, penalizaciones contractuales, costo de las medidas alternas) y por día; valor del activo (AV), factor de exposición (EF) y SLE = AV × EF por proceso crítico y por cada proceso importante que trate los datos personales que la ficha cuantifica (fila de titulares del bloque «Economía»). Un mismo proceso admite un SLE por escenario (cifrado o indisponibilidad, exposición de datos, fraude, sabotaje de la operación), cada uno con su EF y su identificador SLE-nn; E.05 cita el que corresponde a cada riesgo. En esos procesos el escenario es la exposición de los datos: AV = número de titulares de la ficha × costo de notificar a un titular de la ficha, más los otros costos por titular que la ficha cuantifica, y EF = proporción de titulares expuestos en el escenario. Registrar en BIA_P02 (secciones 8 y 9) y en la tabla B.2; BIA_P07 los resume.
10. Fijar la frontera (Paso 9): dejar escrito en el informe que ARO y ALE pertenecen al análisis de riesgos y que el equipo los calcula en E.05 con estos SLE.
11. Declarar el método de valoración (Paso 11) en la sección 10 de BIA_P02 de cada proceso con ficha — cuantitativo, cualitativo o semicuantitativo—; BIA_P06 registra solo los supuestos y límites del método, y la sección 3 de BIA_P07 lo resume; cuando faltan datos históricos, declarar el supuesto con su fuente; considerar FAIR (rangos en lugar de valores puntuales) como alternativa.

12. Someter los supuestos al análisis de sensibilidad (Paso 12) en BIA_P06: cada supuesto con origen y fecha; escenarios mínimo, esperado y máximo para AV y EF (el ARO se varía en E.05); identificar las variables que gobiernan la conclusión.
13. Redactar el informe ejecutivo (Paso 13) en BIA_P07 con sus nueve secciones: resumen ejecutivo, alcance y método, procesos priorizados, costo de la indisponibilidad, puntos únicos de falla y brechas, frontera con el análisis de riesgos, justificación del control (que se completa en E.05), análisis de sensibilidad, recomendaciones y aprobación. Las secciones 8 a 11 se marcan «se completa en E.05» en la entrega de H2 y se completan en la versión 1.1 de BIA_P07, que se entrega junto con E.05 el viernes 23 de octubre.
14. Consolidar en la plantilla E03: tablas B.1 (métricas y criticidad), B.2 (cuantificación), B.3 (estacionalidad y alternos), B.4 (puntos únicos de falla) y B.5 (supuestos y sensibilidad), con los siete anexos adjuntos.

Plantilla E03_BIA_Consolidacion_Procesos_Criticos.docx — llenado campo por campo

Formato oficial: 03_Plantillas_Entregables/E03_BIA_Consolidacion_Procesos_Criticos.docx, junto con los siete anexos 04_Anexos_BIA/BIA_P01…P07.docx. Las filas «(p. ej.)» de la plantilla se reemplazan por los datos de la organización.

Campo	Cómo se completa
B.1 Proceso · Dueño · Puntaje · Clasificación	Nombre exacto de BIA_P01, dueño del organigrama, puntaje de BIA_P05, clase crítico / importante / diferible; tabla ordenada por puntaje.
B.1 MTPD (MTD) · RTO · WRT · RPO · MBCO	De BIA_P02, en horas o minutos; RTO + WRT ≤ MTPD cumplido en cada fila; MBCO como nivel reducido de servicio en una línea.
B.2 Costo por hora · por día · componentes	De BIA_P02 (sección 8); los componentes nombrados (ingresos no percibidos, personal, penalizaciones, medidas alternas y otros costos directos).
B.2 Escenario · AV · EF · SLE · Método	Una fila por proceso y escenario, con su identificador SLE-nn: AV en dólares, EF entre 0 y 1, SLE = AV × EF, en cada proceso crítico y en cada proceso importante con los datos personales que cuantifica la ficha (AV = titulares × costo de notificar a un titular); método de valoración declarado en la sección 10 de BIA_P02.
B.3 Períodos pico · Procedimiento alterno · Duración máxima sostenible · Recurso mínimo	De BIA_P02 y BIA_P04.
B.4 Clase de dependencia · Punto único de falla · Se traslada a E.05 como	Texto literal de BIA_P06 con su clase; el ID de riesgo se completa en la versión 1.1 de E.03, que se entrega junto con E.05 el viernes 23 de octubre.
B.5 Supuesto · Origen · Tres escenarios · Variable que gobierna	De BIA_P06; una fila por supuesto de AV y EF.
Supuestos declarados en este entregable	Solo lo que ni el perfil ni la ficha de datos del cliente traen, con identificador global S-nn, supuesto y fundamento; un dato de la ficha nunca se sustituye por un supuesto. E.11 los consolida en su Anexo A.

Ejemplo resuelto — Red Hospitalaria Metropolitana (RHM, IG3)

Para RHM, el proceso «Gestión de expedientes clínicos electrónicos (EHR)» resulta con MTPD de 4 horas, RTO de 2 horas, WRT de 2 horas (reintroducir lo registrado en papel; 2 + 2 = 4 ≤ 4, cumple en el límite), RPO de 15 minutos y MBCO de atender urgencias con registro en papel sin cirugía programada; procedimiento alterno en papel sostenible 8 horas; costo de indisponibilidad de 12 000 dólares por hora (cirugías programadas canceladas, personal improductivo y costo del procedimiento alterno) y 288 000 por día. Los puntos únicos de falla son la segmentación laxa entre la red administrativa y la médica y la ausencia de inventario de los dispositivos médicos conectados. El valor del proceso se fija en 800 000 dólares con factor de exposición 0,5 para el escenario de cifrado del expediente

clínico: SLE = 400 000. «Admisión y facturación» resulta importante y trata los datos personales de los pacientes que cuantifica la ficha (310 000 con expediente clínico): su AV de exposición es 310 000 × 0,40 dólares de notificar a un paciente = 124 000 y, con EF 1 para la exposición de toda la base, SLE = 124 000. Ahí termina el BIA; E.05 continúa con ARO 0,4 y ALE 160 000.

Proceso	Clase	MTPD	RTO	WRT	RPO	Costo/h	AV	EF	SLE
EHR	Crítico (1.º)	4 h	2 h	2 h	15 min	12 000	800 000	0,5	400 000
IoMT	Crítico (2.º)	(ficha)	(ficha)	(ficha)	(ficha)	(ficha)	(ficha)	(ficha)	(ficha)
Admisión y facturación	Importante	(ficha)	(ficha)	(ficha)	(ficha)	(ficha)	124 000	1,0	124 000
Farmacia y laboratorio	Importante	(ficha)	(ficha)	(ficha)	(ficha)	(ficha)	(ficha)	(ficha)	(ficha)

Errores frecuentes

- Usar solo tres cortes de tiempo o cuatro categorías: el método del proyecto es el de la Guía BIA, con cinco y cinco.
- Fijar RTO y WRT que sumados exceden el MTPD.
- Que el área de tecnología fije el MTPD: lo declara el negocio.
- Incluir ARO y ALE dentro del BIA; pertenecen al análisis de riesgos de E.05.
- Omitir la duración máxima sostenible del procedimiento alterno o la estacionalidad.
- Entregar la consolidación sin los siete anexos BIA_P01–P07 o sin el método de valoración declarado.
- Copiar las cifras del caso RHM en otra organización: cada equipo toma las cifras de la ficha de su organización y declara como supuesto solo lo que la ficha no trae.
- Llenar BIA_P02, BIA_P03 y BIA_P04 para un solo proceso o para todo el censo: se llenan para cada proceso crítico de la precalificación.

Checklist de cierre (correspondencia con la rúbrica)

☐ BIA_P01–P07 completos y adjuntos; cada ficha evalúa cinco categorías en cinco cortes y registra estacionalidad y procedimiento alterno con duración máxima sostenible. [J.1.3]

☐ Todo el censo de BIA_P01 está precalificado en BIA_P05 en el corte de 24 horas (o con la regla declarada); cada proceso crítico tiene BIA_P02, BIA_P03 y BIA_P04 completos, con MTPD, RTO, WRT, RPO y MBCO y RTO + WRT ≤ MTPD, y cada importante y diferible tiene su fila en BIA_P05. [J.1.3]

☐ La tabla B.1 está ordenada por puntaje con clase crítico / importante / diferible, y B.2 trae costo por hora y por día, AV, EF y SLE de cada proceso crítico, y el SLE de exposición de datos de cada proceso importante con los datos personales que cuantifica la ficha, con una fila por escenario y el método de valoración declarado en la sección 10 de BIA_P02. [J.1.3]

☐ B.4 recoge todos los puntos únicos de falla de BIA_P06 con su clase de dependencia; B.3 y BIA_P04 mapean las seis clases, el recurso mínimo y las interdependencias. [J.1.3]

☐ Los supuestos están declarados con origen y fecha y variados en tres escenarios (B.5); el informe ejecutivo (BIA_P07) tiene completas sus secciones 2 a 13, con las secciones 8 a 11 marcadas «se completa en E.05» en la entrega de H2, y enuncia la frontera con el análisis de riesgos; la versión 1.1 de E.03 (B.4 con los ID de riesgo) y de BIA_P07 (secciones 8 a 11) se entrega junto con E.05. [J.1.3]

Entrega

Cuándo	Formato	Nombre del archivo en Moodle
viernes 16 de octubre	DOCX o PDF de la consolidación + los siete anexos BIA en un solo envío	E03_BIA_Consolidacion_Procesos_Criticos_<Equipo>.docx/.pdf

Qué alimenta

E.04 inventaría los activos de las seis clases de dependencia de los procesos críticos; E.05 toma los SPOF como vulnerabilidades, el MTPD y el costo por hora para valorar el impacto, y el SLE para calcular ARO, ALE, beneficio, ACC y ROSI (pasos 9 y 10 de la Guía BIA); E.12 abre con el panorama que el BIA produce.

E.04 — Inventario y clasificación de activos críticos

Fase	Semana de construcción	Entrega	Evalúa
PLAN	S3–S4	viernes 16 de octubre	J.1.4 — E.04 Activos críticos (2 %)

Objetivo

Identificar y clasificar los activos que sostienen los procesos críticos del BIA: información, software, hardware, servicios, personas clave, instalaciones e identidades y cuentas, con dueño y clasificación de confidencialidad. Fundamento: CIS Controls v8.1 (2024), controles 1, 2 y 3.

Insumos

- E.03: procesos críticos ordenados y sus dependencias (BIA_P04).
- Perfil del catálogo: sistemas, red, centro de datos, terceros.

Pasos

1. Tomar cada proceso crítico de E.03 —y cada proceso importante que trate datos personales o tenga un punto único de falla— y listar, desde BIA_P04, los activos de las siete categorías que lo sostienen (orientación: entre doce y veinte activos).
2. Asignar un ID correlativo (A-01, A-02…) y el dueño del organigrama del perfil.
3. Clasificar la información en pública, interna, confidencial o restringida; marcar «Sí» en datos personales cuando aplica la LPDP y clasificar al menos como confidencial.
4. Verificar la regla de calidad: cada proceso tiene al menos un activo de información, uno de plataforma (software o hardware) y uno de personas o terceros.
5. Anotar en la columna 8 los ID de riesgo de E.05 que tomará cada activo (se completa al cerrar E.05); los que no reaparecen, con una línea de justificación.

Plantilla E04_Inventario_Clasificacion_Activos.docx — llenado campo por campo

Formato oficial: 03_Plantillas_Entregables/E04_Inventario_Clasificacion_Activos.docx. Las filas «(p. ej.)» de la plantilla se reemplazan por los datos de la organización.

Campo	Cómo se completa
ID	A-nn correlativo; se usa sin cambios en E.05.
Activo	Nombre concreto (sistema, equipo, contrato, rol, sede), nunca genérico.
Categoría	Una de las siete: información, software, hardware, servicios, personas clave, instalaciones, identidades y cuentas.

Campo	Cómo se completa
Proceso crítico que sostiene	Nombre exacto del proceso de E.03.
Dueño	Rol del organigrama del perfil.
Clasificación	Pública / interna / confidencial / restringida.
Datos personales	Sí / No; «Sí» obliga a confidencial o restringida y a la LPDP.
Supuestos declarados en este entregable	Solo lo que ni el perfil ni la ficha de datos del cliente traen, con identificador global S-nn, supuesto y fundamento; un dato de la ficha nunca se sustituye por un supuesto. E.11 los consolida en su Anexo A.

Ejemplo resuelto — Red Hospitalaria Metropolitana (RHM, IG3)

ID	Activo	Categoría	Proceso	Dueño	Clasificación	DP
A-01	Sistema EHR/HIS (Cerner)	Software	EHR	Dirección de TI	Restringida	Sí
A-02	Monitores y bombas de infusión en red	Hardware (IoMT)	IoMT	Dirección Médica	Confidencial	Sí
A-03	Red médica y centro de datos VMware	Hardware / instalaciones	EHR, IoMT, LIS	Dirección de TI	Restringida	No
A-04	Personal de enfermería de cuidados intensivos	Personas clave	IoMT	Dirección Médica	Interna	No
A-05	Proveedor de soporte del EHR	Servicios de terceros	EHR	Dirección de TI	Confidencial	Sí

Errores frecuentes

- Inventariar solo software y hardware; las personas clave y los terceros son activos.
- Clasificar como «interna» información con datos de salud: son datos personales sensibles y quedan al menos como confidenciales.
- Activos sin dueño o con «TI» como dueño de todo.
- Activos que no aparecen en E.05 y sin justificación.

Checklist de cierre (correspondencia con la rúbrica)

☐ Cada proceso crítico de E.03 tiene activo de información, de plataforma y de personas o terceros. [J.1.4]

☐ Todos los activos tienen ID, categoría, proceso, dueño y clasificación; los de datos personales están marcados. [J.1.4]

☐ Los activos con datos personales están clasificados al menos como confidenciales. [J.1.4]

☐ Cada activo reaparece en E.05 o trae su justificación de ausencia; esta comprobación se cierra en la versión 1.1 de E.04, posterior a E.05. [J.1.4]

Entrega

Cuándo	Formato	Nombre del archivo en Moodle
viernes 16 de octubre	DOCX o PDF	E04_Inventario_Clasificacion_Activos_<Equipo>.docx/.pdf

Qué alimenta

E.05 valora los riesgos activo por activo con estos ID; E.07 y E.08 mapean las salvaguardas de los controles 1, 2 y 3 sobre este inventario.

E.05 — Matriz de riesgos

Fase	Semana de construcción	Entrega	Evalúa
PLAN	S4–S5	viernes 23 de octubre	J.1.5 — E.05 Matriz de riesgos (4 %)

Objetivo

Identificar, valorar y priorizar los riesgos sobre los activos críticos como probabilidad × impacto (escalas 1–5), con riesgo inherente, tratamiento, control CIS asociado y riesgo residual, y presentar el mapa de calor. Fundamento: NIST SP 800-30 r1.

Insumos

- E.03: puntos únicos de falla (B.4), MTPD y costo por hora (B.1, B.2).
- E.04: activos con ID.
- Perfil del catálogo: sistemas, red y madurez actual, leídos con los cinco ejes de amenaza del curso (IA, identidad, nube, terceros y cadena de suministro, tecnología de operación).
- Guía BIA: valor del proceso, factor de exposición, SLE; aquí se completan ARO y ALE.

Pasos

1. Declarar el apetito de riesgo de la dirección simulada (p. ej. ningún riesgo Crítico o Alto sin tratamiento; Medios aceptables con justificación).
2. Por cada activo de E.04, enumerar amenazas plausibles del sector y del perfil. Ejes de amenaza activos del perfil: los cinco ejes del curso —IA, identidad, nube, terceros y cadena de suministro, tecnología de operación — aplicados a los sistemas, la red y la madurez actual que el perfil describe (p. ej. un perfil con SCADA activa OT; uno con Azure activa nube; todos activan identidad y terceros). El equipo registra al menos un riesgo por eje activo y anota en una línea cuáles no aplican.
3. Tomar cada punto único de falla de E.03 como vulnerabilidad de al menos un riesgo.
4. Valorar probabilidad e impacto con las escalas D.1 y D.2; el costo por hora del BIA y el MTPD sustentan el nivel de impacto.
5. Calcular el inherente (P × I), ubicarlo en el mapa de calor D.3 y clasificarlo Crítico / Alto / Medio / Bajo.
6. Asignar tratamiento (mitigar, transferir, evitar, aceptar) y, cuando es mitigar, el control CIS v8.1 que lo reduce. Cuando el riesgo proviene de una dependencia de personas o proveedores sin salvaguarda CIS aplicable, se cita el control de ISO/IEC 27002:2022 y se declara en una línea.
7. Estimar el residual esperado tras el tratamiento y verificar que cae dentro del apetito declarado; el impacto residual puede bajar por el procedimiento alterno probado del BIA (B.3), y la probabilidad por el control CIS.
8. Completar la tabla D.6 para los riesgos Críticos (y para los Altos de nivel 15 o 16 cuando hay menos de tres Críticos) con los pasos 9 y 10 de la Guía BIA: tomar de E.03 (B.2) el SLE del proceso y del escenario que corresponden al riesgo, citado con su identificador SLE-nn; cuando el riesgo es de confidencialidad sobre un proceso importante con los datos personales que cuantifica la ficha, el SLE es el de exposición de datos que B.2 trae para ese proceso; estimar el ARO con la convención de la plantilla (nivel de D.1 → ARO: 5 ≈ 1 · 4 ≈ 0,5 · 3 ≈ 0,2 · 2 ≈ 0,1 · 1 ≈ 0,05) o con una fuente citada; efectividad = reducción de al menos un nivel de probabilidad o del EF, justificada en una línea; adquisición anualizada a cinco años; (1) ALE actual = SLE × ARO; (2) efectividad del control propuesto; (3) ALE con el control; (4) beneficio = diferencia; (5) ACC en sus tres familias (adquisición anualizada, operación, mantenimiento); ROSI = (Beneficio − ACC) ÷ ACC; el control se justifica cuando el ACC es menor que la reducción de ALE. Un ROSI de varios cientos por ciento es esperable en organizaciones de

madurez baja con SLE grandes y controles sin cotización; antes de aceptarlo, el equipo revisa el SLE de E.03, el ARO y las tres familias del ACC.

9. Someter el ARO a los escenarios mínimo, esperado y máximo (Paso 12 de la Guía BIA) en la tabla D.7 y declarar si el control se justifica en los tres.
10. Volver a E.03 y anotar en B.4 el ID de riesgo que tomó cada SPOF, y en la columna 8 de E.04 los riesgos de cada activo; las versiones 1.1 de E.03, E.04 y BIA_P07 (secciones 8 a 11) se entregan junto con E.05.

Plantilla E05_Matriz_Riesgos.docx — llenado campo por campo

Formato oficial: 03_Plantillas_Entregables/E05_Matriz_Riesgos.docx. Las filas «(p. ej.)» de la plantilla se reemplazan por los datos de la organización.

Campo	Cómo se completa
ID	R-nn correlativo; se usa sin cambios en E.07.
Activo	El ID y nombre de E.04.
Amenaza · Vulnerabilidad	Amenaza concreta (ransomware, compromiso de credenciales, manipulación de dispositivo) y la debilidad que la habilita.
P · I	Enteros 1–5 según D.1 y D.2, con una línea de justificación en la columna «Justificación de P e I» de D.5.
Inherente	P × I y su nivel.
Tratamiento	Una de las cuatro opciones; «aceptar» exige firma de la dirección simulada.
Control CIS asociado	Número del control de CIS Controls v8.1; los seis de E.07 salen de aquí. Cuando no hay salvaguarda CIS aplicable, se cita el control de ISO/IEC 27002:2022 y se declara.
Residual	P × I esperado tras el tratamiento; dentro del apetito.
D.6 SLE · ARO · ALE actual	SLE de E.03 (B.2) del proceso y escenario del riesgo, con su identificador SLE-nn; ARO justificado; ALE = SLE × ARO.
D.6 Efectividad · ALE con control · Beneficio	Reducción del ARO o del EF sustentada; ALE con control; beneficio = ALE actual − ALE con control.
D.6 ACC · ROSI	ACC = adquisición + operación + mantenimiento; ROSI = (Beneficio − ACC) ÷ ACC.
Supuestos declarados en este entregable	Solo lo que ni el perfil ni la ficha de datos del cliente traen, con identificador global S-nn, supuesto y fundamento; un dato de la ficha nunca se sustituye por un supuesto. E.11 los consolida en su Anexo A.

Ejemplo resuelto — Red Hospitalaria Metropolitana (RHM, IG3)

RHM registra R-01: activo A-01 (EHR/HIS), amenaza ransomware que cifra el expediente clínico, vulnerabilidad «segmentación laxa entre la red administrativa y la médica», P = 4 (el sector salud reporta ransomware con frecuencia), I = 5 (supera el MTPD de 4 horas y compromete la seguridad de los pacientes), inherente 20 · Crítico, tratamiento mitigar con los controles 12 y 13, residual 2 × 4 = 8 · Medio. Cuantificación: SLE 400 000, ARO 0,4, ALE inherente 160 000; con el control, ARO 0,15 y ALE 60 000; beneficio 100 000 frente a un costo anual del control de 45 000 (ROSI 122 %). R-02 toma el segundo SPOF (dispositivos IoMT sin inventario ni actualización) con los controles 1 y 7.

ID	Activo	Amenaza	P	I	Inherente	Trat.	CIS	Residual
R-01	A-01 EHR/HIS	Ransomware	4	5	20 Crítico	Mitigar	12, 13	8 Medio

ID	Activo	Amenaza	P	I	Inherente	Trat.	CIS	Residual
R-02	A-02 IoMT	Manipulación / indisponibilidad	4	5	20 Crítico	Mitigar	1, 7	8 Medio
R-03	A-01 EHR/HIS	Compromiso de credenciales del personal médico	4	4	16 Alto	Mitigar	5, 6	6 Medio
R-04	A-05 Proveedor EHR	Acceso remoto del proveedor sin control	3	4	12 Alto	Mitigar	15, 6	4 Bajo

Errores frecuentes

- Matrices con menos de doce riesgos o con todos los riesgos en el mismo nivel.
- Valorar el impacto sin apoyarse en el MTPD y el costo por hora del BIA.
- Calcular el ALE con un SLE que E.03 no entregó para ese proceso y escenario, o sin variar el ARO en tres escenarios.
- Amenazas genéricas sin vulnerabilidad concreta del perfil.
- Residual igual al inherente con tratamiento «mitigar».
- Olvidar los ejes de amenaza activos del perfil: IA, identidad, nube, terceros, tecnología de operación.

Checklist de cierre (correspondencia con la rúbrica)

☐ Hay al menos doce riesgos que cubren los activos críticos de E.04, con P e I justificados en las escalas. [J.1.5]

☐ Cada punto único de falla de E.03 aparece como vulnerabilidad de un riesgo. [J.1.5]

☐ Los ejes de amenaza activos del perfil (IA, identidad, nube, terceros, OT) aparecen entre las amenazas, con nota de los que no aplican. [J.1.5]

☐ Todo riesgo tiene inherente, tratamiento, control CIS asociado cuando mitiga y residual dentro del apetito declarado. [J.1.5]

☐ Cada riesgo Crítico tiene su fila D.6 completa: SLE de E.03 del escenario que corresponde, ARO, ALE actual, efectividad, ALE con control, beneficio, ACC en tres familias y ROSI, con el ARO variado en tres escenarios. [J.1.5]

☐ El mapa de calor D.5-bis muestra cada ID en su celda, el apetito de riesgo (D.4-bis) está escrito y firmado, y la tabla D.7 declara si cada control se justifica en los tres escenarios de ARO. [J.1.5]

Entrega

Cuándo	Formato	Nombre del archivo en Moodle
viernes 23 de octubre	DOCX o PDF (registro + mapa de calor)	E05_Matriz_Riesgos_<Equipo>.docx/.pdf

Qué alimenta

E.07 selecciona los seis controles desde los riesgos Críticos y Altos; E.08 mapea el resto; E.12 presenta el mapa de calor como panorama de riesgos.

E.06 — Matriz RACI

Fase	Semana de construcción	Entrega	Evalúa
PLAN	S5	viernes 23 de octubre	J.1.6 — E.06 Matriz RACI (1 %)

Objetivo

Asignar responsables, aprobadores, consultados e informados de las actividades de seguridad de la organización, con los roles reales de su organigrama.

Insumos

- Perfil del catálogo: estructura organizacional.
- E.05: tratamientos que exigen actividades nuevas.
- E.02: firmantes y responsable de seguridad.

Pasos

1. Tomar la tabla base de la plantilla E06 (ocho actividades) y sustituir las columnas por los roles del organigrama del perfil más las funciones creadas como supuesto en E.02 (p. ej. responsable de seguridad); RR. HH., Legal y Auditoría se ubican bajo la unidad del organigrama que el equipo declare; cuando la función no existe en el perfil, el equipo declara quién la asume o que se contrata fuera, y lo justifica en una línea.
2. Añadir las actividades propias del sector y las que los tratamientos de E.05 exigen.
3. Asignar exactamente una A por fila y al menos una R; C e I según necesidad.
4. Verificar que el responsable de seguridad y la dirección aparecen coherentes con E.02.

Plantilla E06_Matriz_RACI.docx — llenado campo por campo

Formato oficial: 03_Plantillas_Entregables/E06_Matriz_RACI.docx. Las filas «(p. ej.)» de la plantilla se reemplazan por los datos de la organización.

Campo	Cómo se completa
Actividad de seguridad	Verbo + objeto; una fila por actividad, incluidas las del sector.
Dirección · Resp. de Seguridad · TI / Operaciones · Dueño del proceso · Legal / Cumplimiento · RR. HH. (encabezados de columna)	Se sustituyen por los roles del organigrama del perfil, con los nombres del catálogo; el número de columnas se ajusta al organigrama.
Valor de cada celda	A (una por fila), R (al menos una), C, I o guion.
Supuestos declarados en este entregable	Solo lo que ni el perfil ni la ficha de datos del cliente traen, con identificador global S-nn, supuesto y fundamento; un dato de la ficha nunca se sustituye por un supuesto. E.11 los consolida en su Anexo A.

Ejemplo resuelto — Red Hospitalaria Metropolitana (RHM, IG3)

RHM sustituye las columnas por Dirección General, Dirección Médica, Dirección de TI, Seguridad de la Información (función creada como supuesto en E.02), Ingeniería Biomédica, Calidad y Seguridad del Paciente y Administración y Finanzas, y añade las filas «Inventariar y monitorear dispositivos IoMT» (A: Dirección de TI; R: Ingeniería Biomédica; C: Dirección Médica) y «Aprobar reglas de filtrado entre la red administrativa y la médica» (A: Dirección de TI; R: Seguridad de la Información; C: Dirección Médica).

Errores frecuentes

- Dos A en una fila o filas sin R.
- Roles genéricos («Gerencia») en lugar del organigrama del perfil.
- RACI sin las actividades que los tratamientos de E.05 introducen.

Checklist de cierre (correspondencia con la rúbrica)

- ☐ Cada fila tiene exactamente una A y al menos una R. [J.1.6]
- ☐ Las columnas son roles del organigrama del perfil o funciones declaradas como supuesto en E.02. [J.1.6]
- ☐ Están añadidas las actividades propias del sector y las derivadas de los tratamientos de E.05. [J.1.6]

Entrega

Cuándo	Formato	Nombre del archivo en Moodle
viernes 23 de octubre	DOCX o PDF	E06_Matriz_RACI_<Equipo>.docx/.pdf

Qué alimenta

E.07 toma los roles para «roles y responsabilidades» de cada política y SOP; E.09 toma el responsable de medir cada indicador.

E.07 — Seis controles a profundidad (política + SOP + controles)

Fase	Semana de construcción	Entrega	Evalúa
DO	S6	viernes 30 de octubre	J.1.7 — E.07 Seis controles a profundidad (3 %)

Objetivo

Seleccionar los seis controles de CIS Controls v8.1 que mitigan los riesgos Críticos y Altos de E.05 y desarrollar cada uno con política, procedimiento operativo (SOP) y controles técnicos, administrativos y físicos, con correspondencia a ISO/IEC 27002:2022 y a la función de NIST CSF 2.0 (2024).

Insumos

- E.05: riesgos Críticos y Altos con su control CIS asociado.
- E.06: roles para la política y el SOP.
- E.02: objetivos de seguridad.
- Documento oficial CIS Controls v8.1 (2024), bloque «Tecnología» de la ficha de datos del cliente (productos y versiones) y lista oficial de CIS Benchmarks.

Pasos

1. Listar los controles CIS que aparecen en la columna «Control CIS asociado» de los riesgos Críticos y Altos y contar cuántos riesgos cubre cada uno.
2. Elegir los seis que más riesgo reducen; a igual conteo, primero el control que cubre riesgos Críticos, después el de mayor suma de inherentes cubiertos, después el que trata el riesgo con mayor pérdida por evento único (SLE) después el que cubre un riesgo que ningún otro candidato de la lista del paso 1 trata y, si persiste el empate, el control que implementa el tratamiento valorado en la tabla D.6 de E.05; escribir la justificación de la selección, con los ID de riesgo y el criterio que decidió cada lugar, en la sección F.0 de la plantilla, idéntica en los seis archivos.
3. Por cada control, completar F.1 (identificación): todas las salvaguardas del IG asignado que pertenecen al control (tomadas de la tabla G.2 de E08), marcando cuáles implementa el diseño ahora y cuáles pasan al roadmap de E.10; riesgos que mitiga, controles ISO/IEC 27002:2022 relacionados, función CSF 2.0.
4. Redactar la política (F.2): propósito, alcance, declaraciones numeradas y verificables, roles de E.06, cumplimiento y excepciones, revisión.
5. Redactar el SOP (F.3): disparador, responsable y frecuencia, pasos numerados con herramientas y criterios, evidencia generada, escalamiento.
6. Definir de dos a cuatro controles por tipo (F.4). Los controles técnicos usan la pila del bloque «Tecnología» de la ficha y citan el CIS Benchmark del producto en la versión que la ficha declara, tomado de la lista oficial de CIS

Benchmarks; si la lista no publica esa versión, se cita el Benchmark de la versión publicada más cercana y se declara; si el producto no tiene Benchmark, se cita la guía de endurecimiento del fabricante y se declara. Cuando la versión declarada ya no tiene soporte del fabricante, se registra como hallazgo en F.4 —producto, versión y fecha de fin de soporte con la fuente del fabricante— y su actualización o sustitución pasa a E.10 como iniciativa.

7. Repetir para los seis controles en seis archivos con la plantilla E07; verificar que cada riesgo Crítico o Alto está cubierto por al menos uno.

Plantilla E07_Desarrollo_Control_CIS.docx — llenado campo por campo

Formato oficial: 03_Plantillas_Entregables/E07_Desarrollo_Control_CIS.docx. Las filas «(p. ej.)» de la plantilla se reemplazan por los datos de la organización.

Campo	Cómo se completa
F.0 Selección de los seis controles (común a los seis archivos)	Los seis controles elegidos, los riesgos que cubre cada uno y el criterio del paso 2 que decidió su lugar; el mismo texto en los seis archivos.
F.1 Control CIS v8.1	Número y nombre oficial de la edición 8.1.
F.1 Salvaguardas del IG asignado en este control	Número, nombre e IG de todas las salvaguardas del control que pertenecen al IG asignado; cada una marcada «diseñada ahora» o «al roadmap». Nombre oficial en inglés o su traducción literal (tabla G.2 de E08).
F.1 Riesgos que mitiga	ID de E.05; sin ID no hay justificación.
F.1 Correspondencia ISO · Función CSF	Códigos de ISO/IEC 27002:2022 (p. ej. 8.22) y una de las seis funciones.
F.2 Declaraciones de política	Reglas numeradas, verificables, sin verbos de intención.
F.3 Pasos numerados	Secuencia completa; cada paso con herramienta y criterio de decisión.
F.3 Evidencia generada	El registro que el indicador de E.09 medirá.
F.4 Controles por tipo	Técnicos, administrativos y físicos; concretos para el perfil. Los técnicos citan el CIS Benchmark de la versión que declara la ficha, y cada versión sin soporte del fabricante queda registrada como hallazgo.
Supuestos declarados en este entregable	Solo lo que ni el perfil ni la ficha de datos del cliente traen, con identificador global S-nn, supuesto y fundamento; un dato de la ficha nunca se sustituye por un supuesto. E.11 los consolida en su Anexo A.

Ejemplo resuelto — Red Hospitalaria Metropolitana (RHM, IG3)

RHM selecciona, desde R-01 a R-04 y el resto de riesgos Críticos y Altos: Control 13 (monitoreo y defensa de la red, por la segmentación laxa), Control 1 (inventario de activos empresariales, por los IoMT sin inventario), Control 7 (gestión continua de vulnerabilidades, por el software de equipos sin actualizar), Control 6 (gestión del control de acceso, por el compromiso de credenciales), Control 11 (recuperación de datos, por el RPO de 15 minutos del EHR) y Control 15 (gestión de proveedores de servicios, por el acceso remoto del proveedor del EHR). Para el Control 13 la política declara: «Todo tráfico entre la red administrativa y la red médica atraviesa un punto de filtrado con reglas aprobadas por el responsable de seguridad»; el SOP de revisión trimestral de reglas deja como evidencia el registro de cambios del firewall interno; correspondencia ISO/IEC 27002:2022 8.20 y 8.22; función Proteger.

Errores frecuentes

- Elegir controles por familiaridad y no por los riesgos de la matriz.
- Política y SOP fusionados: la política declara la regla, el SOP prescribe los pasos.
- Declaraciones de política no verificables («se procurará mantener actualizados los sistemas»).

- SOP sin evidencia generada: sin evidencia, el indicador de E.09 no tiene fuente.
- Controles técnicos sin el CIS Benchmark de la versión que declara la ficha (o, a falta de Benchmark, sin la guía de endurecimiento del fabricante), o una versión sin soporte del fabricante que no se registra como hallazgo.

Checklist de cierre (correspondencia con la rúbrica)

☐ Los seis controles se justifican con los ID de riesgos Críticos y Altos de E.05; cada Crítico queda cubierto por uno de los seis y cada Alto por uno de los seis, por salvaguardas nombradas de E.08 o, cuando E.05 no le asigna salvaguarda CIS, por el control ISO/IEC 27002:2022 de E.05 con su iniciativa en la tabla I.3 de E.10. [J.1.7]

☐ Cada control tiene F.1 completo con todas las salvaguardas del IG asignado del control (diseñadas ahora / al roadmap), correspondencia ISO/IEC 27002:2022 y función CSF 2.0. [J.1.7]

☐ Cada política tiene declaraciones numeradas y verificables, con roles coherentes con E.06. [J.1.7]

☐ Cada SOP tiene pasos numerados, responsable, frecuencia, evidencia generada y escalamiento. [J.1.7]

☐ Cada control documenta de dos a cuatro controles técnicos, administrativos y físicos concretos; los técnicos citan el Benchmark de la versión de la ficha y registran como hallazgo cada versión sin soporte. [J.1.7]

Entrega

Cuándo	Formato	Nombre del archivo en Moodle
viernes 30 de octubre	Seis archivos DOCX o PDF, 3–5 páginas de desarrollo cada uno (F.1 a F.4), sin contar portada, índice, instrucciones ni la sección F.0	E07_Desarrollo_Control_CIS_<Control>_<Equipo>.docx/.pdf

Qué alimenta

E.08 excluye estos seis del checklist del baseline; E.09 mide su evidencia; E.11 los integra como sección 8; E.12 los presenta como los seis controles clave.

E.08 — Baseline según el Grupo de Implementación asignado

Fase	Semana de construcción	Entrega	Evalúa
DO	S6–S7	viernes 6 de noviembre	J.1.8 — E.08 Baseline según el IG asignado (3 %)

Objetivo

Mapear, para los controles fuera de los seis de E.07, todas las salvaguardas del IG asignado, que en todo el catálogo es IG3 (153 salvaguardas, acumulativas: 56 de IG1, 74 de IG2 y 23 de IG3) con la medida que las cubre en la organización, su estado y la evidencia esperada.

Insumos

- E.01: IG asignado.
- E.07: los seis controles excluidos del checklist.
- E.04: inventario para los controles 1–3.
- Documento oficial CIS Controls v8.1 (2024), lista de salvaguardas por IG.
- Bloque «Controles que ya existen» de la ficha de datos del cliente.

Pasos

1. Repartir los doce controles del checklist entre los integrantes —el llenado completo exige de cinco a siete horas de equipo— y dejar al oficial de calidad la revisión del conjunto. Tomar la tabla G.2 de la plantilla E08,

pre-poblada con las 153 salvaguardas de CIS Controls v8.1 (número, nombre e IG), y conservarla completa: el IG asignado es IG3 en las veintisiete organizaciones, de modo que el baseline son las 153 filas.

2. Eliminar las filas de los seis controles de E.07 (documentados en su F.1) y comprobar el conteo: filas IG1 de E.08 + salvaguardas IG1 de las seis F.1 = 56; total de E.08 + F.1 = 153, el IG3 asignado.
3. Por cada salvaguarda, escribir la medida que la cubre en la organización (una línea), el estado (existente / existente parcial / cubierta por tercero / por implementar / al roadmap) y la evidencia esperada. La columna «Estado» lleva un solo valor: «existente», «existente parcial» y «cubierta por tercero» describen la situación actual de la organización; «por implementar» y «al roadmap» describen la propuesta del diseño. Los estados «existente» y «existente parcial» salen del bloque «Controles que ya existen» de la ficha: «existente» cuando la ficha describe la medida con la cobertura que pide la salvaguarda, «existente parcial» cuando la describe con cobertura incompleta, con la brecha declarada, y toda salvaguarda que la ficha no menciona toma uno de los otros tres estados; cero existentes es válido en organizaciones de madurez baja; en perfiles con tecnología de operación, la medida distingue TI y OT. Cuando varias salvaguardas del mismo control se cubren con una misma medida, se escribe una vez y las demás la referencian. «Cubierta por tercero» corresponde a la salvaguarda que se cumple a través de un proveedor con contrato vigente y que la organización no ejecuta: la fila nombra al proveedor, la cláusula contractual que la hace exigible y la evidencia que el proveedor entrega. Cuando la cláusula aún no está firmada, la salvaguarda queda «por implementar» y la medida es la cláusula que el diseño propone incluir en el contrato.
4. Marcar «al roadmap» solo lo que las dependencias impiden implantar en el corto plazo; esas filas pasan a E.10. Marcar «cubierta por tercero» solo con el proveedor, la cláusula contractual y la evidencia nombrados en la fila; sin esos tres datos la salvaguarda queda «por implementar» o «al roadmap».
5. Contar las salvaguardas por estado y presentar el resumen (existentes, existentes parciales, cubiertas por tercero, por implementar, al roadmap).

Plantilla E08_Checklist_Baseline_IG.docx — llenado campo por campo

Formato oficial: 03_Plantillas_Entregables/E08_Checklist_Baseline_IG.docx. Las filas «(p. ej.)» de la plantilla se reemplazan por los datos de la organización.

Campo	Cómo se completa
Control · Salvaguarda	Número y nombre oficial de la edición 8.1.
IG	IG1, IG2 o IG3 según el documento oficial.
Medida que la cubre	Concreta para el perfil; sin frases genéricas.
Estado	Un solo valor. Estado actual: existente o existente parcial, solo con la medida que describe el bloque «Controles que ya existen» de la ficha, y en el parcial con la brecha residual declarada, que pasa a E.10; cubierta por tercero, con contrato vigente, el proveedor, la cláusula contractual que la hace exigible y la evidencia que el proveedor entrega. Propuesta del diseño: por implementar o al roadmap.
Evidencia esperada	El registro, reporte o configuración que probará la salvaguarda.
Supuestos declarados en este entregable	Solo lo que ni el perfil ni la ficha de datos del cliente traen, con identificador global S-nn, supuesto y fundamento; un dato de la ficha nunca se sustituye por un supuesto. E.11 los consolida en su Anexo A.

Ejemplo resuelto — Red Hospitalaria Metropolitana (RHM, IG3)

RHM es IG3: su baseline son las 153 salvaguardas. Fuera de los seis controles desarrollados quedan doce controles a mapear. Salvaguarda 2.1 (inventario de software, IG1): medida «inventario del software del EHR/HIS, PACS, LIS y estaciones clínicas en la CMDB», estado «por implementar», evidencia «reporte trimestral de la CMDB».

Salvaguarda 8.2 (recolección de bitácoras, IG1): medida «recolección centralizada de bitácoras de servidores del centro de datos VMware», estado «por implementar». Salvaguarda 18.1 (programa de pruebas de penetración, IG2): estado «al roadmap», dependencia «inventario y segmentación operando». Salvaguarda 10.1 (antimalware desplegado, IG1): la ficha registra antivirus en estaciones y servidores Windows, de modo que el estado es «existente parcial», con la brecha declarada: los activos que no usan Windows, como los equipos médicos conectados, no tienen antimalware registrado.

Control	Salvaguarda	IG	Medida	Estado	Evidencia
2	2.1 Inventario de software	IG1	CMDB con software clínico y de escritorio	Por implementar	Reporte CMDB
8	8.2 Recolectar bitácoras	IG1	Recolección central en el centro de datos	Por implementar	Configuración del recolector
10	10.1 Antimalware desplegado	IG1	Antivirus en estaciones y servidores Windows (ficha); brecha en los activos que no usan Windows	Existente parcial	Consola del antivirus con cobertura por activo
18	18.1 Programa de pruebas de penetración	IG2	Programa anual con tercero	Al roadmap	Contrato y plan
16	16.1 Proceso de desarrollo seguro	IG2	Desarrollo del EHR/HIS a cargo del proveedor bajo su ciclo de desarrollo seguro	Cubierta por tercero	Cláusula de desarrollo seguro del contrato e informe anual del proveedor

Errores frecuentes

- Mapear solo las salvaguardas IG1: el baseline es el IG3 completo, las 153.
- Repetir en el checklist los seis controles de E.07.
- Marcar «existente» o «existente parcial» una salvaguarda que el bloque «Controles que ya existen» de la ficha no menciona.
- Enviar todo «al roadmap» para no diseñar medidas.
- Marcar «cubierta por tercero» sin nombrar al proveedor ni la cláusula contractual que la hace exigible.

Checklist de cierre (correspondencia con la rúbrica)

☐ El checklist contiene todas las salvaguardas del IG asignado fuera de los seis controles, con número y nombre oficial de la v8.1. [J.1.8]

☐ Conteo comprobado: IG1 de E.08 + IG1 de las seis F.1 de E.07 = 56, y el total E.08 + F.1 = 153, el IG3 asignado. [J.1.8]

☐ Cada salvaguarda tiene medida concreta, estado y evidencia esperada; los estados «existente» y «existente parcial» corresponden al bloque «Controles que ya existen» de la ficha; el resumen por estado está presente, y cada fila marcada «cubierta por tercero» nombra al proveedor, la cláusula contractual que la hace exigible y la evidencia que el proveedor entrega. [J.1.8]

Entrega

Cuándo	Formato	Nombre del archivo en Moodle
viernes 6 de noviembre	DOCX, PDF o XLSX con la misma estructura de columnas	E08_Checklist_Baseline_IG_<Equipo>.docx/.pdf

Qué alimenta

E.10 ordena en el tiempo las filas «por implementar» y «al roadmap»; E.11 lo integra como sección 9.

E.09 — Indicadores de cumplimiento y auditoría interna

Fase	Semana de construcción	Entrega	Evalúa
CHECK	S7	viernes 6 de noviembre	J.1.9 — E.09 Indicadores y auditoría interna (1 %)

Objetivo

Definir cómo la organización verifica que los seis controles operan: al menos un indicador con ficha completa por control, alimentado por la evidencia del SOP, y una propuesta de auditoría interna conforme a ISO/IEC 27001:2022, cláusula 9.2.

Insumos

- E.07: evidencia generada por cada SOP (F.3).
- E.06: responsables de medir y de recibir el resultado.
- E.05: nivel residual esperado como referencia de meta.

Pasos

1. Por cada control de E.07, tomar la evidencia del SOP y formular un indicador: nombre, fórmula (numerador / denominador × 100 o conteo), meta y umbral de alerta, frecuencia, fuente del dato, responsable de E.06 (la R de la actividad mide; la A recibe el resultado).
2. Comprobar que cada indicador mide el control y no la actividad («porcentaje de dispositivos inventariados» mide el Control 1; «número de reuniones» no mide nada).
3. Diseñar la auditoría interna con los seis elementos de H.2: alcance y objetivo, criterios, método y muestra, programa, informe y hallazgos, seguimiento. Cuando el organigrama del perfil no incluye auditoría interna, el equipo declara quién ejerce la independencia —un tercero contratado o una unidad ajena a la operación del control— y lo justifica.
4. Vincular el seguimiento de hallazgos con el roadmap de E.10 (acciones correctivas).

Plantilla E09_Indicadores_Auditoria_Interna.docx — llenado campo por campo

Formato oficial: 03_Plantillas_Entregables/E09_Indicadores_Auditoria_Interna.docx. Las filas «(p. ej.)» de la plantilla se reemplazan por los datos de la organización.

Campo	Cómo se completa
Nombre · Fórmula	Qué mide, con numerador y denominador definidos.
Meta · Umbral	Valor objetivo y valor que dispara alerta.
Frecuencia · Fuente	Mensual, trimestral o por evento; el registro del SOP que la alimenta.
Responsable	Rol de E.06 que mide y rol que recibe.
H.2 Alcance y objetivo · Criterios · Método y muestra · Programa · Informe y hallazgos · Seguimiento	Los seis elementos de la tabla H.2, adaptados al perfil; el seguimiento enlaza con el roadmap de E.10.
Supuestos declarados en este entregable	Solo lo que ni el perfil ni la ficha de datos del cliente traen, con identificador global S-nn, supuesto y fundamento; un dato de la ficha nunca se sustituye por un supuesto. E.11 los consolida en su Anexo A.

Ejemplo resuelto — Red Hospitalaria Metropolitana (RHM, IG3)

RHM, Control 1: «porcentaje de dispositivos IoMT registrados en la CMDB respecto de los descubiertos en la red médica», fórmula registrados / descubiertos × 100, meta 100 %, alerta bajo 95 %, mensual, fuente: reporte de descubrimiento pasivo y CMDB, mide Ingeniería biomédica y recibe la Dirección de TI. Control 13: «porcentaje de reglas de filtrado entre segmentos revisadas en el trimestre», meta 100 %, fuente: registro de cambios del firewall interno. La auditoría interna simulada cubre los seis controles con revisión documental, verificación de evidencias del SOP y entrevistas a la Dirección Médica y a TI, con auditor independiente del área de Calidad y Seguridad del Paciente, en el primer trimestre del año simulado.

Errores frecuentes

- Indicadores sin fórmula ni meta.
- Fuente del dato distinta de la evidencia que el SOP genera.
- Auditoría sin auditor independiente o sin formato de hallazgo.
- Seguimiento de hallazgos desconectado del roadmap.

Checklist de cierre (correspondencia con la rúbrica)

☐ Cada control de E.07 tiene al menos un indicador con los seis campos de la ficha completos. [J.1.9]

☐ La fuente de cada indicador es la evidencia del SOP correspondiente y el responsable está en E.06. [J.1.9]

☐ La propuesta de auditoría interna trae los seis elementos de H.2 con auditor independiente y formato de hallazgo. [J.1.9]

Entrega

Cuándo	Formato	Nombre del archivo en Moodle
viernes 6 de noviembre	DOCX o PDF	E09_Indicadores_Auditoria_Interna_<Equipo>.docx/.pdf

Qué alimenta

E.10 recibe las acciones correctivas previstas; E.11 lo integra como sección 10.

E.10 — Roadmap de madurez hacia el IG asignado

Fase	Semana de construcción	Entrega	Evalúa
ACT	S8	miércoles 11 de noviembre	J.2.4 — E.10 Roadmap de madurez (2 %)

Objetivo

Ordenar en tres horizontes (0–6, 6–18, 18–36 meses) las salvaguardas pendientes del baseline de E.08, la estabilización de los seis controles y las mejoras que la auditoría anticipa, con dependencias y responsables, hasta alcanzar el IG asignado.

Insumos

- E.08: filas «por implementar» y «al roadmap».
- E.07: los seis controles a estabilizar y las salvaguardas marcadas «al roadmap» en su F.1.
- E.09: acciones correctivas previstas.
- E.01: IG asignado (IG3 en todo el catálogo).
- E.05: tratamientos de riesgos sin salvaguarda CIS (control ISO/IEC 27002:2022).

- E.02 y ficha de datos del cliente: objetivos con fecha absoluta y arranque del programa el lunes 4 de enero de 2027.

Pasos

1. Agrupar en iniciativas las salvaguardas pendientes de E.08 y las marcadas «al roadmap» en la F.1 de los seis controles de E.07 (una iniciativa reúne salvaguardas que se implantan juntas).
2. Asignar a cada iniciativa horizonte, responsable de E.06, dependencias y resultado esperado. Los horizontes se cuentan desde el arranque del programa que fija la ficha, el lunes 4 de enero de 2027: corto plazo del 4 de enero al 30 de junio de 2027 (0–6 meses), mediano plazo del 1 de julio de 2027 al 30 de junio de 2028 (6–18 meses) y largo plazo del 1 de julio de 2028 al 31 de diciembre de 2029 (18–36 meses).
3. Ordenar: IG1 pendiente en el corto plazo; IG2 en el mediano; IG3 en el largo. Una iniciativa de IG2 o IG3 se adelanta cuando trata un riesgo Crítico o Alto de E.05, sirve a un objetivo de E.02 cuya fecha cae en un horizonte anterior o cumple una obligación legal o contractual, y se pospone cuando una dependencia lo exige; el motivo se escribe en la columna «Dependencias».
4. Verificar que ninguna iniciativa entra en un horizonte antes de que sus dependencias estén cubiertas.
5. Registrar en la tabla I.3 los tratamientos de E.05 que no tienen salvaguarda CIS (control ISO/IEC 27002:2022), con responsable, horizonte y resultado esperado, fuera del conteo de las 153.
6. Cerrar con la tabla I.2, estado esperado al final de cada horizonte: cuántas salvaguardas de IG1, IG2 e IG3 quedan operando al 30 de junio de 2027, al 30 de junio de 2028 y al 31 de diciembre de 2029; al cierre del largo plazo operan las 153 del IG asignado.

Plantilla E10_Roadmap_Madurez_IG.docx — llenado campo por campo

Formato oficial: 03_Plantillas_Entregables/E10_Roadmap_Madurez_IG.docx. Las filas «(p. ej.)» de la plantilla se reemplazan por los datos de la organización.

Campo	Cómo se completa
Iniciativa	Nombre de la acción con su alcance.
Salvaguardas CIS v8.1 · IG	Números de salvaguarda y su IG.
Horizonte	Corto (4-ene a 30-jun-2027) / mediano (1-jul-2027 a 30-jun-2028) / largo (1-jul-2028 a 31-dic-2029).
Responsable	Rol de E.06.
Dependencias	Iniciativas o salvaguardas previas, y el motivo cuando la iniciativa se adelanta o se pospone respecto de su IG.
Resultado esperado	Estado verificable al cierre del horizonte.
I.2 Estado esperado por horizonte	Fecha de arranque del programa y salvaguardas de IG1, IG2 e IG3 operando al cierre de cada horizonte.
I.3 Tratamientos de E.05 sin salvaguarda CIS	Riesgo, control ISO/IEC 27002:2022, iniciativa, responsable, horizonte y resultado esperado; fuera del conteo de las 153.
Supuestos declarados en este entregable	Solo lo que ni el perfil ni la ficha de datos del cliente traen, con identificador global S-nn, supuesto y fundamento; un dato de la ficha nunca se sustituye por un supuesto. E.11 los consolida en su Anexo A.

Ejemplo resuelto — Red Hospitalaria Metropolitana (RHM, IG3)

Iniciativa	Salvaguardas	IG	Horizonte	Dependencias	Resultado
Inventario continuo de dispositivos IoMT	1.1, 1.3, 1.5	IG1–IG3	Corto	Ninguna	100 % de IoMT registrados con dueño
Filtrado entre red administrativa y médica	12.2, 13.4	IG2	Corto	Inventario IoMT	Reglas aprobadas y registro de cambios
Bitácoras centralizadas en SIEM	8.9–8.11, 13.1	IG2	Mediano	Control 8 IG1 operando	Retención de 90 días y alertas
Programa de pruebas de penetración	18.1–18.5	IG2–IG3	Largo	Segmentación y SIEM operando	Prueba anual con hallazgos cerrados

Errores frecuentes

- Roadmap sin dependencias: todo en el corto plazo.
- Iniciativas que no provienen de E.08, de E.09 ni de los tratamientos de E.05 sin salvaguarda CIS de la tabla I.3.
- Enviar las salvaguardas de IG2 e IG3 al largo plazo sin fecha ni dependencia declarada: el IG asignado se alcanza dentro del horizonte de 36 meses.

Checklist de cierre (correspondencia con la rúbrica)

☐ Cada iniciativa trae salvaguardas, IG, horizonte, responsable, dependencias y resultado esperado. [J.2.4]

☐ Todas las filas «por implementar» y «al roadmap» de E.08, y las salvaguardas «al roadmap» de la F.1 de E.07, están cubiertas por una iniciativa. [J.2.4]

☐ La progresión respeta las dependencias y alcanza el IG asignado dentro de los 36 meses; la tabla I.2 trae la fecha de arranque y el estado por horizonte, y la I.3 los tratamientos de E.05 sin salvaguarda CIS. [J.2.4]

Entrega

Cuándo	Formato	Nombre del archivo en Moodle
miércoles 11 de noviembre	DOCX o PDF; se integra en E.11 como sección 11	E10_Roadmap_Madurez_IG_<Equipo>.docx/.pdf

Qué alimenta

E.11 lo integra como sección 11; E.12 lo presenta como tercer bloque de la defensa.

E.11 — Documento final integrado

Fase	Semana de construcción	Entrega	Evalúa
ACT	S8	miércoles 11 de noviembre	J.2 completa (15 %)

Objetivo

Ensamblar el informe de la línea base de seguridad con las trece secciones, a partir de los entregables E.02–E.10 ya retroalimentados, con identidad profesional y toda cifra o afirmación normativa citada con fuente y año. Se evalúa con los cinco criterios de J.2.

Insumos

- E.02 a E.10 en su versión corregida tras la retroalimentación de cada hito.
- E.01 para la portada y los datos del equipo.
- Bibliografía: ediciones y años de cada marco citado.

Pasos

1. Crear el documento sobre la plantilla E11, que trae portada (nombre de la organización, del equipo y de la ESEN; sin logotipos de terceros), registro formal del documento, tabla de contenidos, numeración de páginas, las trece secciones y los anexos A, B y C; cada sección de la estructura corresponde a un entregable, en el orden de la tabla. El ensamblaje parcial de las secciones 1–7 puede iniciarse en la S6.
2. Incorporar E.02 como secciones 2 y 3, E.03 como sección 4 (consolidación en su versión 1.1; los siete anexos BIA_P01–P07 se adjuntan al final del PDF y se listan en el Anexo C del DOCX), E.04 como 5, E.05 como 6 con el mapa de calor, E.06 como 7, E.07 como 8 (seis subsecciones), E.08 como 9, E.09 como 10 y E.10 como 11.
3. Aplicar en cada sección las correcciones recibidas en la retroalimentación del hito; el oficial de calidad registra qué cambió en el Anexo B «Retroalimentación aplicada», una fila por hito, y anota «sin retroalimentación recibida» en el hito que no la tuvo.
4. Consolidar en el Anexo A todos los supuestos declarados de E.01 a E.10, en el orden de su identificador global S-nn, con el supuesto, su fundamento y el entregable que lo declaró.
5. Redactar las conclusiones y recomendaciones al cliente (sección 12): el estado de riesgo, las seis medidas prioritarias y la ruta hacia el IG asignado.
6. Compilar la bibliografía (sección 13) con ediciones y años: CIS Controls v8.1 (2024), ISO/IEC 27001:2022 y 27002:2022, NIST SP 800-30 r1, NIST CSF 2.0 (2024), ISO 22301:2019, ISO/TS 22317:2021, LPDP D.L. 144/2024 y, cuando aplican, la Ley de Ciberseguridad y Seguridad de la Información (D.L. 143/2024) y PCI DSS v4.0.1 (2024), además de los CIS Benchmarks citados con su versión y los reportes citados.
7. Verificar la trazabilidad de extremo a extremo: cada control de la sección 8 nombra riesgos de la 6; cada riesgo Crítico o Alto tiene control o salvaguarda; cada indicador de la 10 mide un control de la 8.
8. Correr el checklist de ensamblaje y exportar a PDF.

Plantilla E11_Documento_Final_LineaBase.docx — estructura del documento final, sección por sección

Formato oficial: 03_Plantillas_Entregables/E11_Documento_Final_LineaBase.docx. Las filas «(p. ej.)» de la plantilla se reemplazan por los datos de la organización.

Sección	Cómo se completa
1. Portada y datos generales	Organización, IG asignado, equipo con roles, fecha, versión.
2. Introducción y compromiso de la dirección	De E.02, A.1, con la firma de la dirección simulada y del responsable de seguridad al cierre de la sección.
3. Alcance del SGSI	De E.02, A.2, con la revisión A.3 de su versión 1.1.
4. BIA	Consolidación de E.03 en su versión 1.1; los anexos BIA_P01–P07 se adjuntan al final del PDF y se listan en el Anexo C.
5. Inventario y clasificación de activos	De E.04.
6. Matriz de riesgos y mapa de calor	De E.05, con apetito de riesgo y cuantificación de los Críticos.
7. Matriz RACI	De E.06.
8. Controles seleccionados (6)	De E.07, una subsección por control.
9. Baseline según el IG asignado	De E.08, con resumen por estado.
10. Indicadores y auditoría interna	De E.09.
11. Roadmap de madurez	De E.10.

Sección	Cómo se completa
12. Conclusiones y recomendaciones al cliente	Redacción nueva del equipo.
13. Bibliografía	Ediciones y años.
Registro formal del documento	Versión, fecha, elaboró (oficial de documentación), revisó (oficial de calidad) y aprobó (consultor líder).
Anexo A — Supuestos declarados	Registro consolidado S-01 a S-nn, en orden, con su fundamento y el entregable que lo declaró.
Anexo B — Retroalimentación aplicada	Una fila por hito: retroalimentación recibida, cambio aplicado y sección afectada.
Anexo C — Anexos del BIA	Lista de BIA_P01–P07 en su versión final; los archivos se adjuntan al final del PDF.

Ejemplo resuelto — Red Hospitalaria Metropolitana (RHM, IG3)

El informe de RHM titula «Línea base de seguridad de la Red Hospitalaria Metropolitana — IG3», integra en la sección 4 la consolidación con el EHR como proceso crítico principal (MTPD 4 h, 12 000 dólares por hora), en la 6 el mapa de calor con R-01 y R-02 en 20 · Crítico, en la 8 los controles 13, 1, 7, 6, 11 y 15, en la 9 el checklist de las 153 salvaguardas con su resumen por estado y en la 11 el roadmap con la segmentación y el inventario IoMT en el corto plazo. Las conclusiones recomiendan a la dirección iniciar por el inventario de dispositivos médicos y el filtrado entre redes, con el argumento económico del ROSI de 122 % del control de R-01.

Errores frecuentes

- Pegar los entregables sin aplicar la retroalimentación recibida.
- Secciones fuera de orden o faltantes; la estructura de trece es fija.
- Cifras y normas sin fuente y año.
- Documento sin portada, índice o numeración de páginas.
- Conclusiones que repiten el resumen en lugar de recomendar.

Checklist de cierre (correspondencia con la rúbrica)

☐ Las trece secciones están presentes, en orden, y cada una proviene del entregable corregido tras la retroalimentación. [J.2.5]

☐ La bibliografía cita cada marco con edición y año, y toda cifra del cuerpo tiene fuente. [J.2.1]

☐ La cadena BIA → activos → riesgos → controles es verificable sección a sección; los seis controles se justifican desde riesgos Críticos y Altos. [J.2.2]

☐ Políticas, SOP y controles son específicos para el perfil, con evidencias definidas y diferencia clara entre política y procedimiento. [J.2.3]

☐ El roadmap de la sección 11 cubre lo pendiente de E.08 y alcanza el IG asignado con dependencias. [J.2.4]

☐ Portada, índice, numeración, registro formal, firma de la declaración en la sección 2, Anexo A de supuestos, Anexo B de retroalimentación aplicada y PDF final con los anexos del BIA cumplidos; el archivo lleva el nombre normalizado. [J.2.5]

Entrega

Cuándo	Formato	Nombre del archivo en Moodle
miércoles 11 de noviembre	PDF (más el DOCX fuente); los siete anexos BIA_P01–P07 se adjuntan al final del PDF y el DOCX los lista en su Anexo C	E11_Documento_Final_LineaBase_<Organizacion>_<Equipo>.docx/.pdf

Qué alimenta

E.12 se construye como síntesis ejecutiva de este documento.

E.12 — Presentación ejecutiva y defensa oral

Fase	Semana de construcción	Entrega	Evalúa
Defensa	12–14 de noviembre	fecha y hora asignadas por el docente	J.3 completa (10 %)

Objetivo

Presentar en diez minutos, en formato ejecutivo y con apoyo visual sobrio, el panorama de riesgos, los seis controles clave y el roadmap, y responder las preguntas del docente a cualquier integrante sobre cualquier parte del proyecto. Se evalúa con los cuatro criterios de J.3.

Insumos

- E.11: documento final.
- E.03 y E.05: cifras del panorama de riesgos y mapa de calor.
- E.07 y E.10: controles y roadmap.

Pasos

1. Construir la presentación sobre la plantilla E12 (PPTX), que trae las nueve diapositivas del guion de la tabla siguiente con su título, su tiempo y el campo «Fuente» al pie; una diapositiva por bloque, texto mínimo, cifras con fuente.
2. Repartir los bloques entre los integrantes, con un suplente por bloque, y escribir en las notas del orador de cada diapositiva quién la presenta y qué dice; cada integrante prepara además los otros bloques, porque las preguntas se dirigen a cualquiera.
3. Ensayar con cronómetro: diez minutos de presentación; el docente detiene al minuto diez. Los tiempos del guion suman diez minutos exactos; el ensayo apunta a nueve, y el minuto restante es margen de transición. La duración de cada ensayo se registra en la diapositiva de anexo «Preparación de la defensa».
4. Preparar las respuestas de justificación: por qué esos seis controles, por qué ese IG, por qué ese orden del roadmap, con los ID de riesgo y las cifras del BIA a la mano; las preguntas preparadas y sus respuestas se escriben en la diapositiva de anexo «Preparación de la defensa», que se entrega y no se proyecta.
5. Entregar la presentación en Moodle antes de la fecha de defensa y llevar el documento final impreso o en pantalla para consulta.

Plantilla E12_Presentacion_Ejecutiva.pptx — guion de la presentación, bloque por bloque (tiempo)

Formato oficial: 03_Plantillas_Entregables/E12_Presentacion_Ejecutiva.pptx. Las filas «(p. ej.)» de la plantilla se reemplazan por los datos de la organización.

Bloque (tiempo)	Cómo se completa
1 · Portada (0:30)	Organización, IG asignado, equipo.
2 · La organización y su alcance (1:00)	Procesos críticos, sedes, sistemas; exclusiones.
3 · Panorama del BIA (1:30)	Procesos críticos con MTPD, RTO y costo por hora; puntos únicos de falla.
4 · Mapa de calor (1:30)	Los riesgos Críticos y Altos ubicados; apetito de riesgo.
5 · Los seis controles clave (2:00)	Control, riesgo que mitiga, salvaguardas y evidencia; el argumento económico de uno de ellos.

Bloque (tiempo)	Cómo se completa
6 · Baseline según el IG (0:45)	Resumen por estado: existentes, por implementar, al roadmap.
7 · Indicadores y auditoría (0:45)	Dos indicadores y el programa de auditoría.
8 · Roadmap (1:30)	Tres horizontes, dependencias, estado final.
9 · Recomendaciones al cliente (0:30)	Las tres decisiones que la dirección toma primero.

Ejemplo resuelto — Red Hospitalaria Metropolitana (RHM, IG3)

El equipo de RHM abre con el hospital y sus cuatro procesos críticos; muestra el EHR con MTPD de 4 horas y 12 000 dólares por hora; ubica R-01 y R-02 en 20 · Crítico y explica la segmentación laxa y los IoMT sin inventario como puntos únicos de falla; presenta los controles 13, 1, 7, 6, 11 y 15 con el ROSI de 122 % del control de red; resume el baseline IG3 por estado; cierra con el roadmap que pone el inventario IoMT y el filtrado entre redes en los primeros seis meses, y recomienda a la dirección aprobar esas dos iniciativas y la revisión trimestral de reglas. Pregunta típica del docente: «¿Por qué el Control 13 y no el 12 como primer control?»; la respuesta cita R-01, la salvaguarda 13.4 y la dependencia con el inventario.

Errores frecuentes

- Leer el documento en lugar de sintetizarlo.
- Diapositivas con párrafos completos.
- Un solo integrante que responde todo.
- Justificar con opiniones y no con los ID de riesgo y las cifras del BIA.
- Exceder los diez minutos.

Checklist de cierre (correspondencia con la rúbrica)

☐ La presentación sigue los nueve bloques con sus tiempos y cabe en diez minutos cronometrados. [J.3.1]

☐ El reparto de bloques con sus suplentes está en las notas del orador y en el anexo «Preparación de la defensa», con la duración de cada ensayo; cada integrante ensayó todos los bloques y puede responder sobre cualquier sección del documento. [J.3.2]

☐ Las preguntas preparadas del anexo «Preparación de la defensa» tienen su respuesta con ID de riesgo, cifras del BIA, salvaguardas y marcos con edición. [J.3.3]

☐ El apoyo visual es sobrio, el tiempo está ensayado y el reparto de bloques muestra trabajo de equipo. [J.3.4]

Entrega

Cuándo	Formato	Nombre del archivo en Moodle
fecha y hora asignadas por el docente	PPTX de la presentación (9 diapositivas con notas del orador y la diapositiva de anexo «Preparación de la defensa»), o su PDF con notas, + defensa de 10 minutos	E12_Presentacion_Ejecutiva_<Organizacion>_<Equipo>.pptx/.pdf

Qué alimenta

Cierra el proyecto.

Anexo J — Rúbricas de evaluación (45 % = 20 + 15 + 10)

Cada criterio lleva el identificador que citan los checklists de cierre de la sección 9; la correspondencia es de uno a uno y se verifica de forma mecánica al generar esta guía. Los pesos de J.1 se agrupan por hito: H1 = 3 %, H2 = 5 %, H3 = 5 %, H4 = 7 %.

J.1 Entregables parciales — 20 %

Id	Criterio	Peso	Criterios de la nota completa
J.1.1	E.01 Acta de equipo y organización	1 %	Acta completa: integrantes con rol, tres preferencias, organización y IG asignados, compromisos firmados; entregada el viernes 25 de septiembre (H1).
J.1.2	E.02 Compromiso y alcance del SGSI	2 %	Declaración con objetivos medibles y compromisos concretos adaptados al perfil; alcance con procesos, sedes, sistemas, exclusiones justificadas y requisitos legales (LPDP donde aplica).
J.1.3	E.03 BIA	3 %	Método de la Guía BIA aplicado: fichas con cinco categorías y cinco cortes, MTPD/RTO/WRT/RPO/MBCO coherentes (RTO + WRT ≤ MTPD), costo por hora, puntos únicos de falla y consolidación ordenada por criticidad con los siete anexos BIA_P01–P07.
J.1.4	E.04 Activos críticos	2 %	Inventario con categoría, proceso que sostiene, dueño, clasificación y marca LPDP; cada proceso crítico con activo de información, de plataforma y de personas o terceros; trazabilidad proceso → activo.
J.1.5	E.05 Matriz de riesgos	4 %	Al menos doce riesgos con escalas 1–5 bien aplicadas; puntos únicos de falla del BIA como vulnerabilidades; ejes de amenaza activos del perfil entre las amenazas; inherente, tratamiento y residual definidos; mapa de calor de la organización; apetito de riesgo declarado y firmado; D.6 y D.7 completas.
J.1.6	E.06 Matriz RACI	1 %	Una sola A por fila, al menos una R, roles del organigrama del perfil y actividades propias del sector añadidas.
J.1.7	E.07 Seis controles a profundidad	3 %	Seis controles completos (identificación, política, SOP, controles por tipo) con trazabilidad a riesgos Críticos o Altos y correspondencia ISO/IEC 27002:2022 y CSF 2.0.
J.1.8	E.08 Baseline según el IG asignado	3 %	Checklist con todas las salvaguardas del IG asignado fuera de los seis controles, cada una con medida, estado y evidencia; conteo comprobado (IG1 de E.08 + IG1 de E.07 = 56; total de E.08 + E.07 = 153, el IG3 asignado).
J.1.9	E.09 Indicadores y auditoría interna	1 %	Al menos un indicador con ficha completa por control desarrollado, alimentado por la evidencia del SOP; propuesta de auditoría interna con los seis elementos de ISO/IEC 27001:2022 §9.2.

J.2 Informe final — 15 %

Id	Criterio	Peso	Criterios de la nota completa
J.2.1	Alineación normativa	3 %	Uso correcto y citado de CIS Controls v8.1, ISO/IEC 27001/27002:2022, NIST SP 800-30 r1 y CSF 2.0; LPDP donde aplica; bibliografía con ediciones y años.
J.2.2	Integración y priorización	4 %	La cadena BIA → activos → riesgos → controles es coherente y verificable; la selección de los seis controles se justifica desde los riesgos Críticos y Altos.
J.2.3	Calidad técnica	4 %	Políticas, SOP y controles viables, específicos para la organización y con evidencias definidas; diferencia clara entre política y procedimiento.
J.2.4	E.10 Roadmap de madurez	2 %	Iniciativas con salvaguardas, IG, horizonte, responsable, dependencias y resultado esperado; progresión coherente con el checklist de E.08 y con el IG asignado.
J.2.5	E.11 Organización y documentación	2 %	Las trece secciones completas y ensambladas desde los entregables retroalimentados; redacción profesional; identidad y formato de entrega cumplidos.

J.3 Defensa oral — 10 %

Id	Criterio	Peso	Criterios de la nota completa
J.3.1	Síntesis ejecutiva	3 %	Panorama de riesgos, seis controles clave y roadmap presentados con claridad en diez minutos.
J.3.2	Dominio del contenido	3 %	Cada integrante responde con solvencia sobre cualquier parte del proyecto.
J.3.3	Justificación de decisiones	3 %	Las respuestas defienden las elecciones desde el análisis: riesgos, marcos y negocio.
J.3.4	Profesionalismo	1 %	Manejo del tiempo, apoyo visual sobrio y trabajo de equipo visible.

Anexo K — Referencia al Catálogo de Empresas 2026

El documento «Catálogo de Empresas del Proyecto Final ESEN 2026» contiene los veintisiete perfiles completos (datos básicos, procesos críticos, infraestructura y madurez) con la justificación de su Grupo de Implementación (sección 4) y las reglas de selección y bloqueo de duplicados (sección 5). Las veintisiete organizaciones están asignadas a IG3, de modo que el baseline de todos los equipos son las 153 salvaguardas de CIS v8.1. La tabla siguiente es la referencia rápida; el perfil completo es la fuente de trabajo del equipo.

N.°	Organización	Sector	IG asignado
1	Banca Unida de Centroamérica (BUNICA)	Servicios Financieros y Banca	IG3
2	Red Hospitalaria Metropolitana (RHM)	Salud	IG3
3	ComunicaTel El Salvador	Telecomunicaciones	IG3
4	Energía Nacional S.A. de C.V. (ENSA)	Energía y Servicios Públicos	IG3
5	Dirección General de Identificación Nacional (DGIN)	Gobierno	IG3
6	LogiPort CA (Puerto Logístico Centroamericano)	Logística y Transporte Marítimo	IG3
7	Innovatec Pharma	Farmacéutica y Biotecnología	IG3
8	Aseguradora Confianza Total	Seguros	IG3
9	Mercado Digital Centroamérica (MerdiCA)	Comercio Electrónico y FinTech	IG3
10	Universidad Tecnológica de Centroamérica (UNITEC-CA)	Educación Superior e Investigación	IG3
11	AeroComponentes de El Salvador (AESA)	Manufactura Avanzada (Aeroespacial)	IG3
12	Supermercados El Ahorro	Retail y Consumo Masivo	IG3
13	OmniSource Solutions	BPO (Business Process Outsourcing) y Centros de Contacto	IG3
14	GestioPyme Cloud	Software como Servicio (SaaS)	IG3
15	Alas Centroamericanas (ALACA)	Aviación y Transporte	IG3
16	Capitalia Gestores de Patrimonio	Gestión de Inversiones y Banca Privada	IG3
17	Centro Judicial Digital de El Salvador (CJDES)	Gobierno / Justicia	IG3
18	GeoExplora El Salvador	Minería y Recursos Naturales	IG3
19	Global Media Group (GMG) - División El Salvador	Medios y Entretenimiento	IG3
20	Constructora Horizonte	Construcción e Ingeniería Civil	IG3
21	Central Azucarera El Gigante (CENAZU)	Agroindustria (Producción de Azúcar)	IG3

N.°	Organización	Sector	IG asignado
22	Express Logistics International (ELI)	Logística y Transporte de Carga	IG3
23	Raíces Bienes Raíces	Inmobiliario y Desarrollo	IG3
24	Cacao del Sol	Alimentos y Bebidas (Chocolate Premium)	IG3
25	CrediRápido S.A.	FinTech (Microcréditos)	IG3
26	Consultores Legales Corpolex	Servicios Legales Corporativos	IG3
27	Instituto Salvadoreño de Investigación Genómica	Investigación Científica y Biotecnología	IG3

Reglas de asignación (sección 5 del catálogo): una organización por equipo, elegida en la primera semana con tres preferencias registradas en el aula virtual; la primera solicitud válida bloquea la organización; dos equipos comparten organización únicamente con autorización expresa del docente, y sus proyectos se desarrollan y evalúan de forma independiente; el cambio de organización después de la primera semana es excepcional y conserva el calendario de hitos.

Referencias

- Center for Internet Security (2024). CIS Critical Security Controls, versión 8.1. Grupos de Implementación: IG1 = 56 salvaguardas, IG2 = 130, IG3 = 153. Documento: https://www.cisecurity.org/controls/v8-1 (descarga sin costo, con registro); consulta en línea sin registro en el CIS Controls Navigator v8.1: https://www.cisecurity.org/controls/cis-controls-navigator.
- Center for Internet Security. CIS Benchmarks: lista oficial de productos y versiones en https://www.cisecurity.org/cis-benchmarks; PDF sin costo para uso no comercial, con registro, en https://learn.cisecurity.org/benchmarks. Se cita el Benchmark de la versión que declara la ficha de datos del cliente (E.07, paso 6).
- ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection — Information security management systems — Requirements.
- ISO/IEC 27002:2022. Information security controls.
- ISO 22301:2019. Security and resilience — Business continuity management systems — Requirements.
- ISO/TS 22317:2021. Guidelines for business impact analysis.
- NIST (2012). SP 800-30 Rev. 1, Guide for Conducting Risk Assessments.
- NIST (2010). SP 800-34 Rev. 1, Contingency Planning Guide for Federal Information Systems.
- NIST (2024). The NIST Cybersecurity Framework (CSF) 2.0.
- Asamblea Legislativa de El Salvador (2024). Ley para la Protección de Datos Personales, Decreto Legislativo N.° 144, Diario Oficial N.° 219, Tomo 445, 15 de noviembre de 2024. Art. 25: notificación de toda vulneración de seguridad de datos personales a la Agencia de Ciberseguridad del Estado, a la Fiscalía General de la República y a los titulares afectados en un plazo máximo de 72 horas. Texto oficial: https://www.asamblea.gob.sv/sites/default/files/documents/decretos/7A4FBD85-7E1B-46BE-9408-6FC549E53E00.pdf.
- Asamblea Legislativa de El Salvador (2024). Ley de Ciberseguridad y Seguridad de la Información, Decreto Legislativo N.° 143, Diario Oficial N.° 219, Tomo 445, 15 de noviembre de 2024. Nota de ámbito (art. 2): obliga a los órganos del Gobierno y sus dependencias, las instituciones oficiales autónomas, las autoridades municipales y toda entidad que administre recursos públicos, ejecute actos de la administración pública o posea incidencia en las infraestructuras críticas de la nación. Texto oficial:

https://www.asamblea.gob.sv/sites/default/files/documents/decretos/D056D9A1-299D-4188-941A-9C3B5898D3F3.pdf.

- PCI Security Standards Council (2024). Payment Card Industry Data Security Standard (PCI DSS), versión 4.0.1. Aplica a las organizaciones cuya ficha de datos del cliente declara pagos con tarjeta; el nivel de comercio o de proveedor de servicios y la forma de validación se toman de la ficha. Biblioteca de documentos: https://www.pcisecuritystandards.org/document_library/ (sin costo, con registro: aceptación de la licencia y datos de contacto).
- ESEN (2026). Guía del Estudiante del BIA y plantillas BIA_P01–P07 (asignación de la Semana 2).
- ESEN (2026). Catálogo de Empresas del Proyecto Final ESEN 2026.